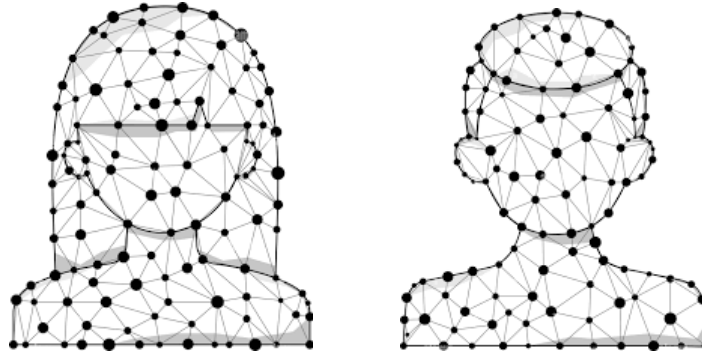




Tecniche e applicazioni biometriche

Fabio Scotti

fabio.scotti@unimi.it

Università degli Studi di Milano

Inizio della breve simulazione di esame inerente alle ottiche e sensori

- NOTA: durante l'insegnamento vi saranno altri momenti dove saranno presentati altri esempi di domande di esame e loro risoluzione.
- Per i motivi descritti all'inizio del corso, non vengono rilasciate in formato pdf le simulazioni parziali di esame, tuttavia al termine dell'insegnamento, nell'ultima lezione sarà fatta una simulazione integrale dell'esame, con relativa correzione e discussione (con pdf pubblicati)
- Seguono 2 esempi

Con un sensore di acquisizione a 3 canali x 8bit per pixel

1. *Si possono ottenere solo 256 colori*
2. *Si possono ottenere solo 16,7 milioni di colori.*
3. *Non sono utilizzabili nei sistemi biometrici perché hanno un numero limitato di colori*
4. *Non sono utilizzabili nei sistemi biometrici perché hanno una risoluzione troppo limitata*

Quali delle affermazioni che seguono sono più corrette?

- Immagini con più larghe (risoluzione) si possono più facilmente acquisire più tratti biometrici.
- Con sensori con maggiore numero di bit per pixel si possono impiegare algoritmi migliori
- Con sensori con maggiore risoluzione si possono analizzare del tratto biometrico scale o livelli diversi.
- Tutte le precedenti.
- Nessuna delle precedenti.

Difesa della Privacy, Protezione del template

Fabio Scotti
fabio.scotti@unimi.it

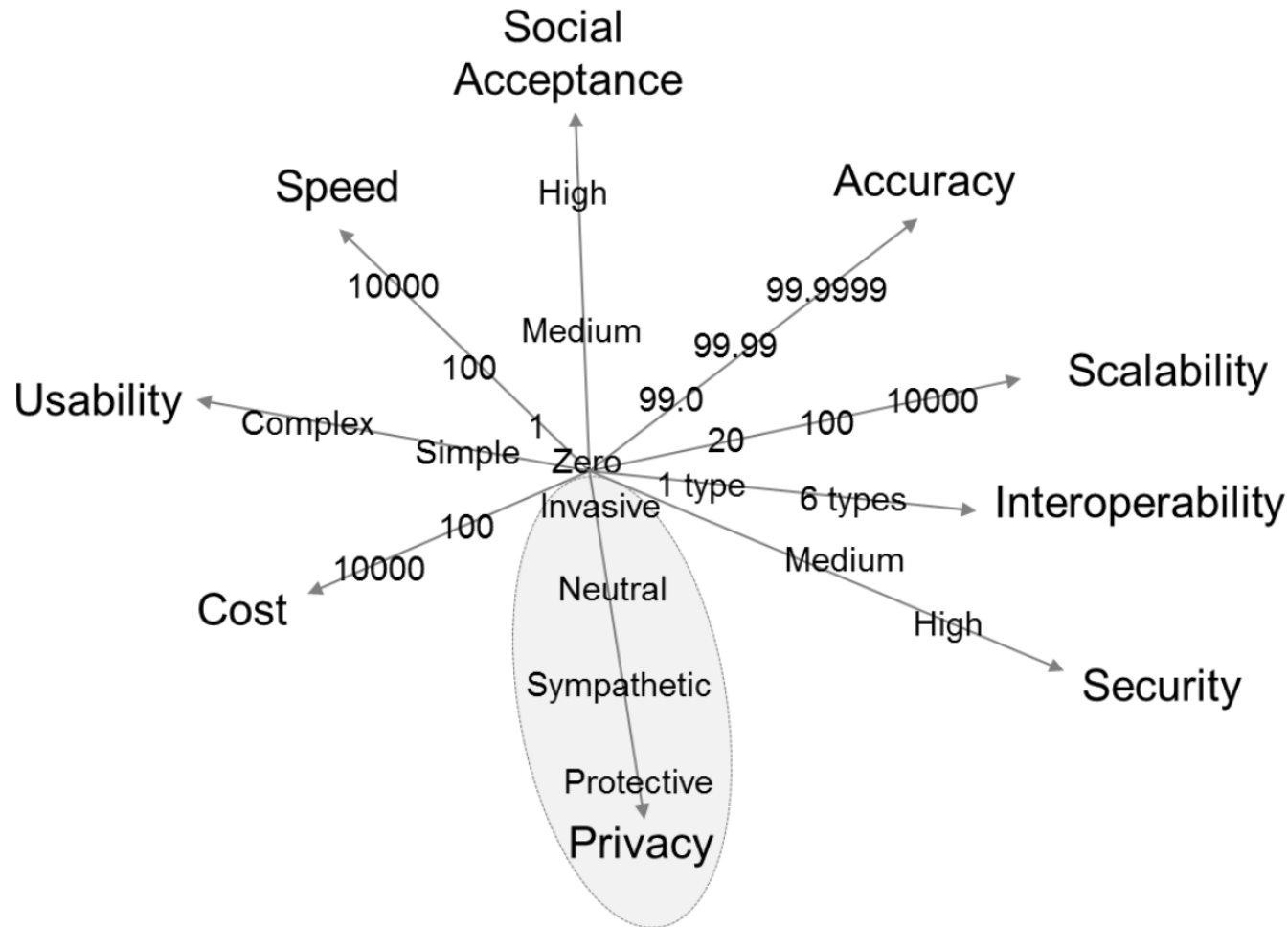
Università degli Studi di Milano



Outline

1. Difesa della Privacy and linee guida
2. Biometria cancellabile
 - Permutazione per iris code
 - Morphing del volto (esempi)
3. Sample o template
 - Ricostruzione del sample
4. Crittazione Biometrica
5. Wordcoins e prime soluzioni commerciali
6. De-identificazione biometrica
7. Discussione della privacy biometria nei social media
8. Ulteriori rischi associati alla heart-biometrics

Uno degli aspetti di progettazione dei sistemi biometrici



4 livelli di privacy biometrica

1. Privacy-protective applications

- La biometria protegge le informazioni personali che altrimenti potrebbero essere compromesse, ad esempio nei contesti di sicurezza aziendale o pubblici.



2. Privacy-sympathetic (consapevole) applications

- Contiene dati biometrici, potrebbero essere usati male, ma si cerca di limitarlo
- La maggiorparte delle applicazioni dove l'utente è obbligato di farlo (confine, aeroporto, banca, lavoro, servizi essenziali) il consenso è formale, ma non del tutto libero



3. Privacy-neutral applications

- Sistemi di autenticazione su device elettronici (*local authentication, user-centric authentication*)
- Non protegge altri dati personali direttamente. Protegge solo l'accesso
- Uso volontario



4. Privacy-invasive applications

- Surveillance applications and some national ID services



Occorre chiedersi: «che tipo di sistema sto progettando?»

«Il rischio della privacy è davvero bilanciato rispetto ai benefici per gli utenti?»

7 domande

Segue un breve elenco di domande ci aiuterà a comprendere i livelli di rischio privacy associati all'applicazione dei sistemi biometrici





Privacy++



Overt

Is the system deployed overtly or covertly?

Covert





Privacy++



Optional

Is the system optional or mandatory?

Mandatory





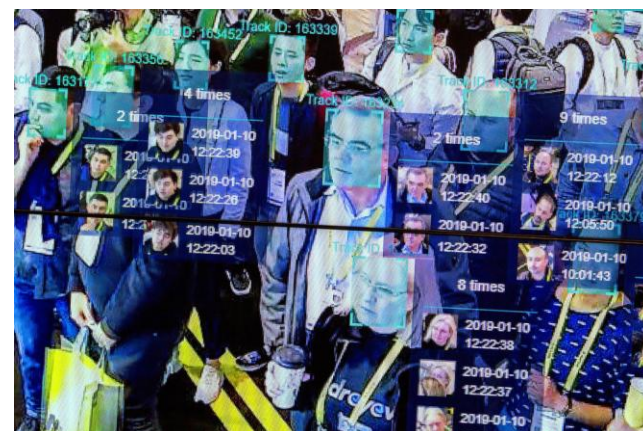
Privacy++



Verification

Is the system used for
Identification or Verification

Identification





Privacy++



**Private Sector
Customer**

Is the system deployed
in the private or public sector?

**Public Sector
Citizen**





Privacy++

Individual
Customer

In what role is the user
interacting with the system?



Employee
Citizen





Privacy++

**Personal
Storage**



**Database
Storage**

Where is the biometric data stored?





Privacy++



Behavioral



Physiological





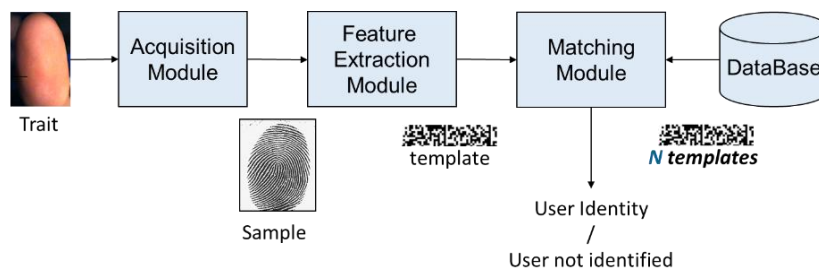
Privacy++



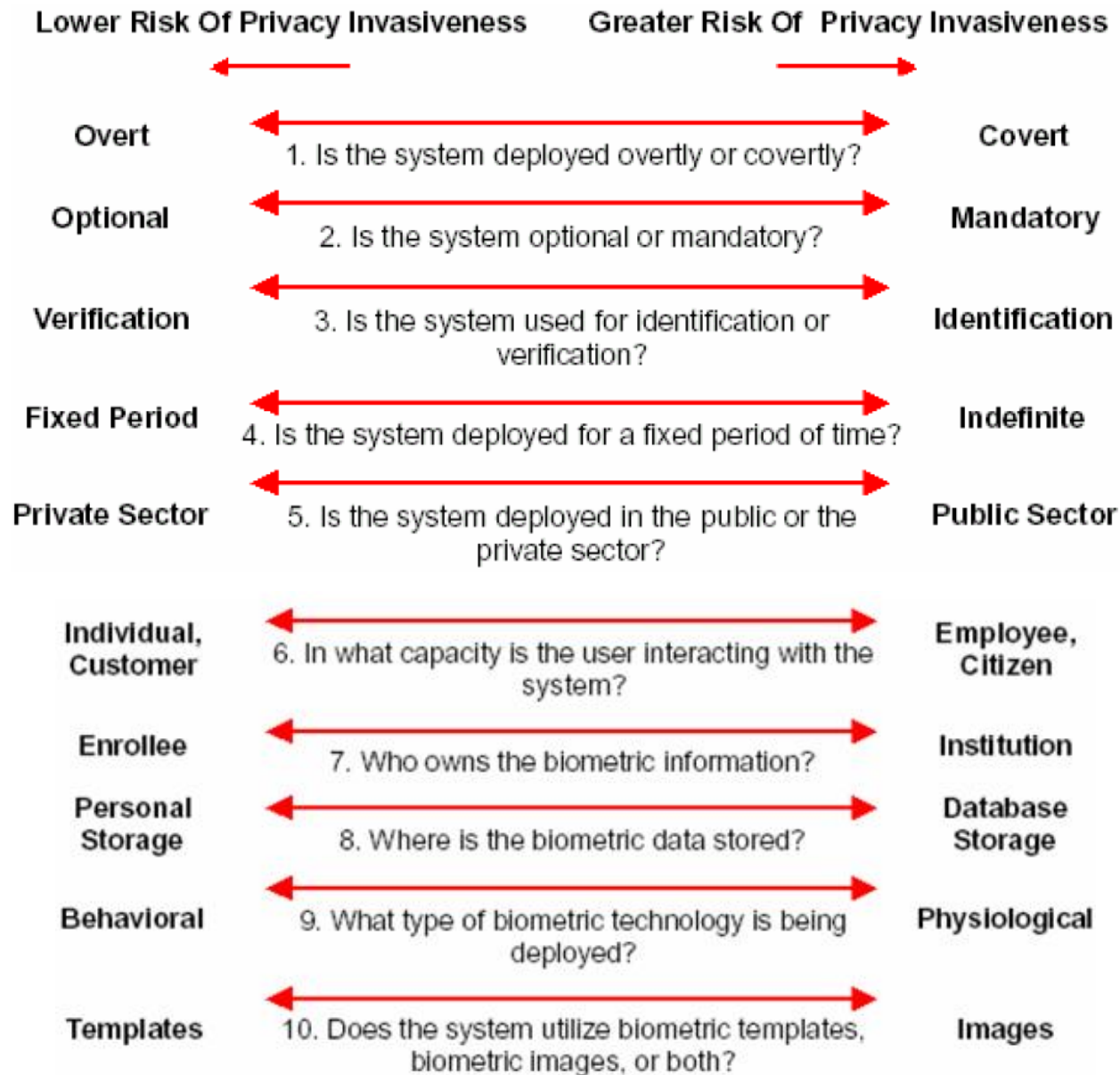
Templates

Does the system use templates,
samples or both?

Sample/
Images



Lista completa



Discussione di un caso di privacy



- Dal 1/12/2019 in Cina chi vuole acquistare un cellulare e una scheda telefonica deve sottoporsi alla scannerizzazione del volto (obbligo del ministero dell'Industria e della tecnologia dell'informazione)
- Si assiste ad un (sicuro) peggioramento della privacy
 - Private Sector → Public Sector
 - Individual customer → Citizena fronte di un (probabile) aumento della sicurezza dichiarato (salvaguardare i diritti legittimi e gli interessi dei cittadini nel cyberspazio»)
- In Cina >800M persone usano Internet (57.7% popolazione) di cui 98% su telefono mobile...



GDPR

- La discussione delle norme e della loro applicazione del Regolamento generale sulla protezione dei dati (GDPR) viene discussa nel corso di Sistemi Biometrici.
- Punti principali
 - I dati biometrici sono compresi nella nuova legge
 - La privacy degli utenti deve essere considerata fin dal design della applicazione (by design)
 - Data breach comunicato in 72 ore (20Meuro..)
 - Titolare del trattamento dei dati - custodi dei dati
 - Cifratura e protezione dei dati
 - Pseudonimizzazione
 - Resilienza del sistema

EU AI ACT → biometria

Sistemi proibiti e ad alto rischio

- L'articolo 5(g) proibisce l'immissione sul mercato, la messa in servizio o l'uso di sistemi di categorizzazione biometrica che deducono o inferiscono attributi sensibili quali razza, opinioni politiche o orientamento sessuale. Tale divieto è specifico e assoluto e mira a impedire ai sistemi di fare inferenze che potrebbero portare a discriminazioni o violazioni della privacy.
- Al contrario, i sistemi di categorizzazione biometrica ad alto rischio, come indicato nell'articolo 6(2) e dettagliati nell'allegato III, sono soggetti a una regolamentazione rigorosa piuttosto che a un divieto assoluto.
- Gli utilizzatori di sistemi di categorizzazione biometrica ad alto rischio devono rispettare obblighi specifici ai sensi dell'articolo 50(3), tra cui l'obbligo di informare gli individui esposti a questi sistemi e di elaborare i dati in conformità al GDPR e ad altre normative UE pertinenti
- I sistemi proibiti sono completamente vietati a causa del loro rischio intrinseco di grave abuso e discriminazione. Al contrario, i sistemi ad alto rischio sono regolamentati per garantire che siano utilizzati in modo responsabile e con le necessarie tutele per proteggere i diritti individuali.
- La differenza sembra risiedere nel fatto che la categorizzazione biometrica sarà considerata ad alto rischio se gli attributi sensibili sono immediatamente evidenti, ma sarà vietata se tali attributi sono dedotti o desunti da altri dati.

EU AI ACT → biometria

- Questa distinzione può **portare a confusione**, in particolare quando la linea tra inferenze sensibili e categorizzazioni legali è sfocata.
 - Ad esempio,
 - un sistema che categorizza le immagini in base al colore dei capelli o degli occhi per scopi di applicazione della legge potrebbe essere **ad alto rischio e regolamentato**,
 - un sistema che deduce le convinzioni politiche di qualcuno dai dati di riconoscimento facciale **è proibito**.
- Inoltre, la **sovrapposizione tra le leggi nazionali** e le disposizioni dell'AI Act aggiunge un ulteriore livello di complessità.
- DATE:
 - 2 febbraio 2025: i sistemi di categorizzazione biometrica di cui all'articolo 5 erano vietati.
 - 2 agosto 2026: entrano in vigore le norme sui sistemi di categorizzazione biometrica.

Divieto di categorizzazione biometrica

Dal 2 agosto 2026 è **VIETATO** usare sistemi di categorizzazione biometrica che inferiscono o assegnano:

- origine razziale o etnica («racial or ethnic origin»)
- convinzioni religiose o filosofiche
- orientamento sessuale
- opinioni politiche
- appartenenza sindacale

Anche se: «l'accuratezza è alta», il dataset è “bilanciato”, l'utente ha firmato un consenso, bla bla..

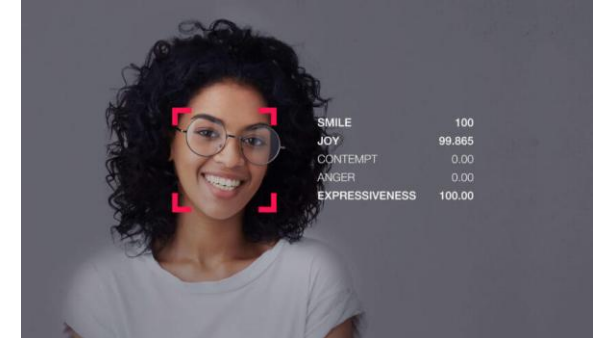
NO, è un divieto strutturale, non mitigabile.

Applicazioni permesse ma regolati (alto rischio)



- Applicazioni come
 - la stima dell'età per accesso a contenuti
 - categorizzazione per sicurezza fisica
 - classificazioni funzionali (es. “adulto/minore”)
- Classificati come high-risk AI systems
- Soggetti a:
 - Risk management
 - Data governance
 - Logging
 - Human oversight
 - Trasparenza

Emotion recognition: caso speciale



- L'AI Act tratta **emotion recognition** quasi come la categorizzazione biometrica.
- **Dal 2 agosto 2026 è VIETATA** in:
 - luoghi di lavoro
 - scuole
- **Fortemente limitata** altrove (trattata come high-risk AI systems)
- Il divieto vale:
 - indipendentemente dal consenso
 - indipendentemente dall'accuratezza
 - indipendentemente dal fine dichiarato

EU AI ACT, biometria: Critiche

- L' AI Act è sufficiente? Alcune associazioni dicono di no! È stato adottato l'Artificial Intelligence Act dell'UE, che stabilisce un divieto di principio sul riconoscimento facciale di massa in tempo reale e altre forme di sorveglianza biometrica pubblica da parte della polizia. Tuttavia, le ampie eccezioni a questo divieto potrebbero spianare la strada alla legittimazione dell'uso di questi sistemi

Sebbene l'AI Act dovrebbe vietare molte pratiche biometriche inaccettabili, abbiamo sostenuto fin dall'inizio che potrebbe invece diventare [un modello per la conduzione del BMS](#).

Come avevamo previsto, l'atto finale compie un passo potenzialmente distopico verso la legalizzazione del riconoscimento facciale pubblico in tempo reale, che finora non è mai stato esplicitamente consentito in nessun paese dell'UE. Lo stesso vale per [i sistemi di lettura della mente pseudoscientifici basati sull'intelligenza artificiale](#), che l'AI Act consente sorprendentemente agli stati di utilizzare in contesti di polizia e di confine. Anche l'uso di macchine per categorizzare il genere delle persone e altre caratteristiche sensibili, in base al loro aspetto, è consentito in diversi contesti.

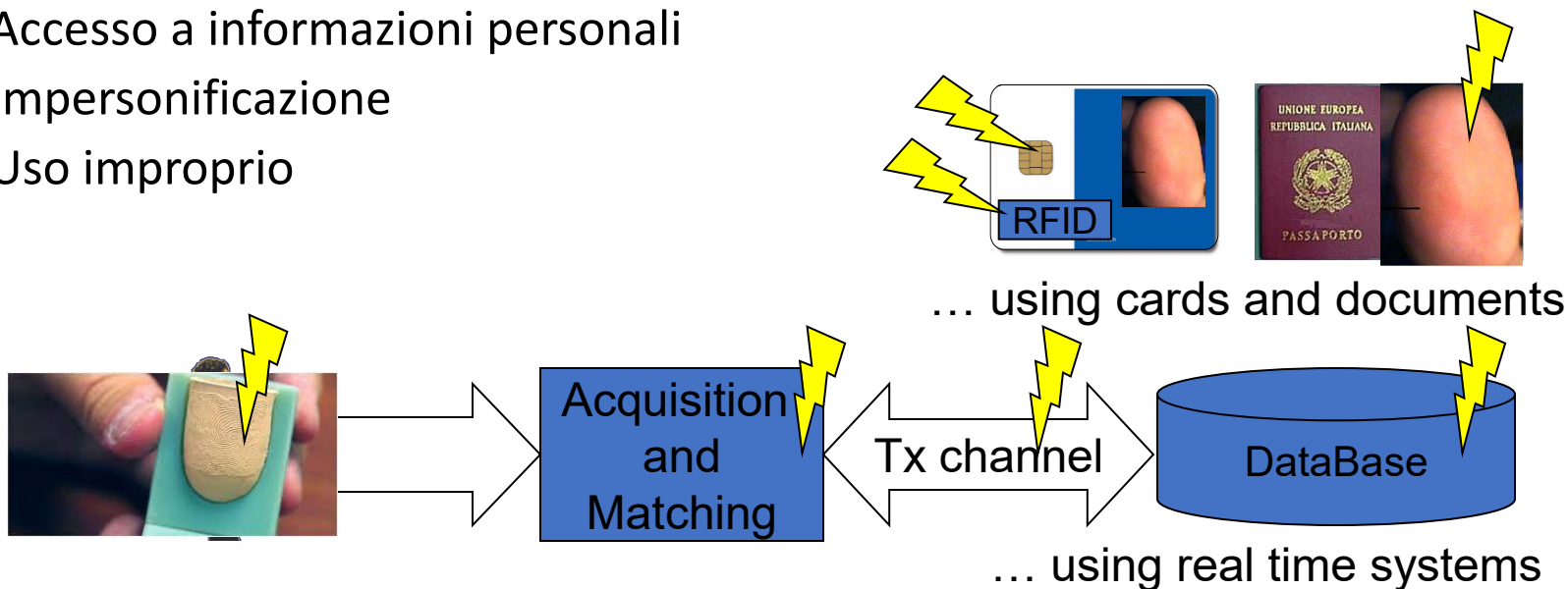
<https://edri.org/our-work/how-to-fight-biometric-mass-surveillance-after-the-ai-act-a-legal-and-practical-guide/>

EU AI ACT, biometria: Critiche (2)

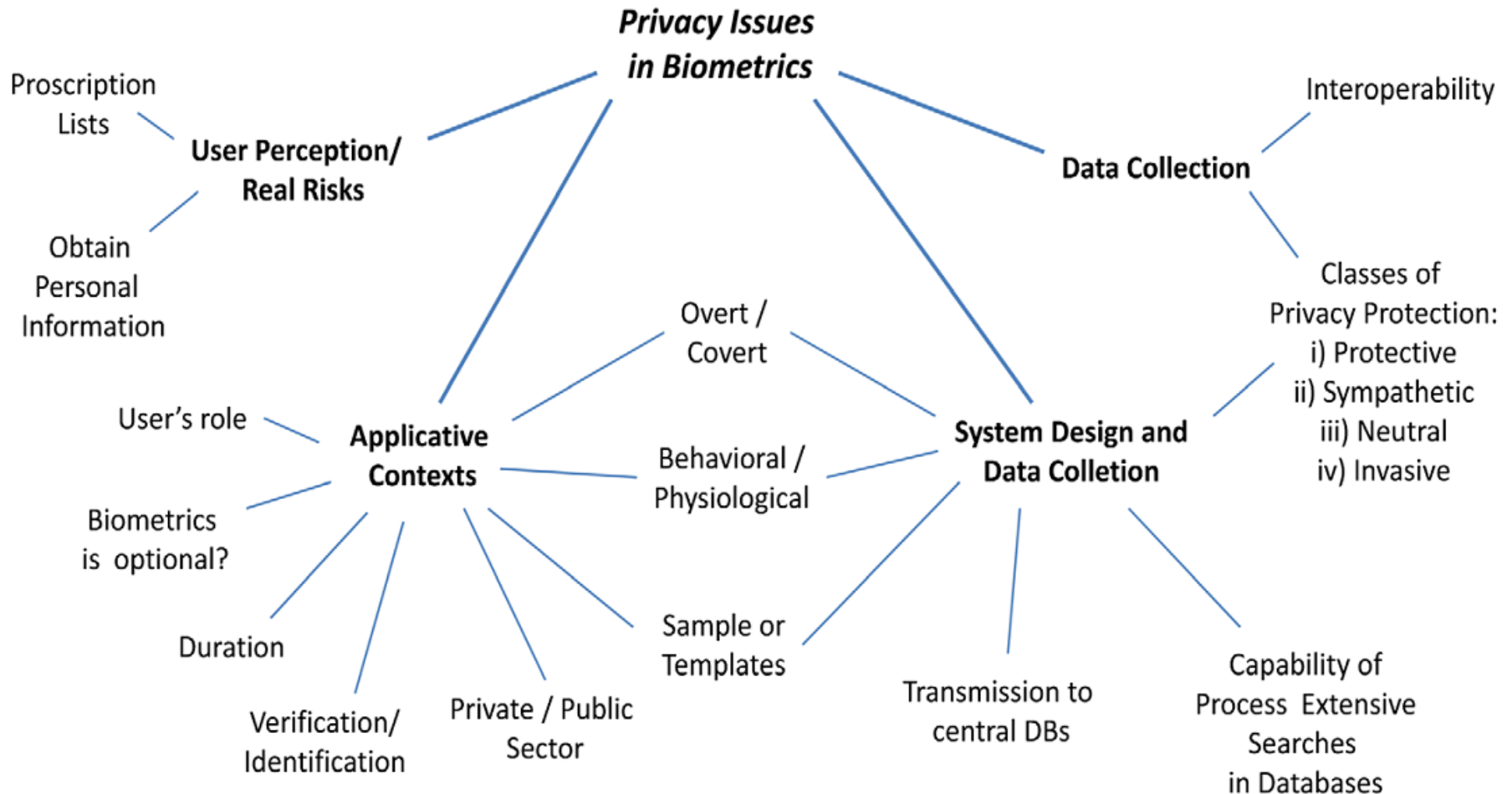
- ARTICLE 19 è lieta di riconoscere che l'AI Act proibisce esplicitamente gli usi pericolosi e dannosi di determinati sistemi di intelligenza artificiale, tra cui la polizia predittiva, il punteggio sociale e l'influenza surrettizia («di atto in cui si tace intenzionalmente un fatto») sul comportamento umano.
- Tuttavia, ARTICLE 19 teme che l'AI Act non riesca a **vietare completamente** l'uso di tecnologie [di riconoscimento emozionale](#) e di identificazione biometrica remota in tempo reale in spazi accessibili al pubblico.

Biometrics privacy ⁽¹⁾

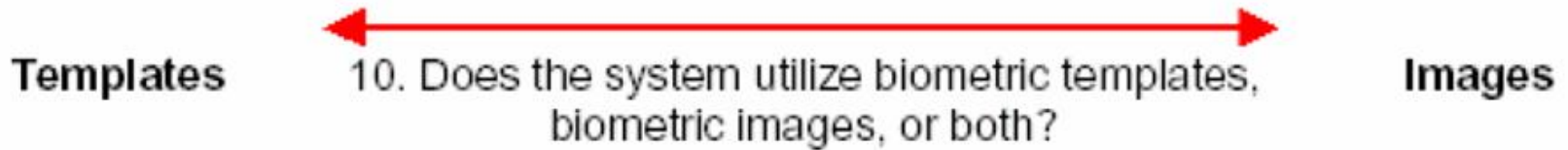
- Controllo sull'uso e sulla divulgazione dell'identità personale e delle informazioni
- L'identità biometrica personale deve essere protetta
- I tratti biometrici non possono essere sostituiti
- Possibili problemi in caso di furto dei tratti biometrici:
 - Accesso a informazioni personali
 - Impersonificazione
 - Uso improprio



Biometrics privacy (2)



Basta usare solo i templates?

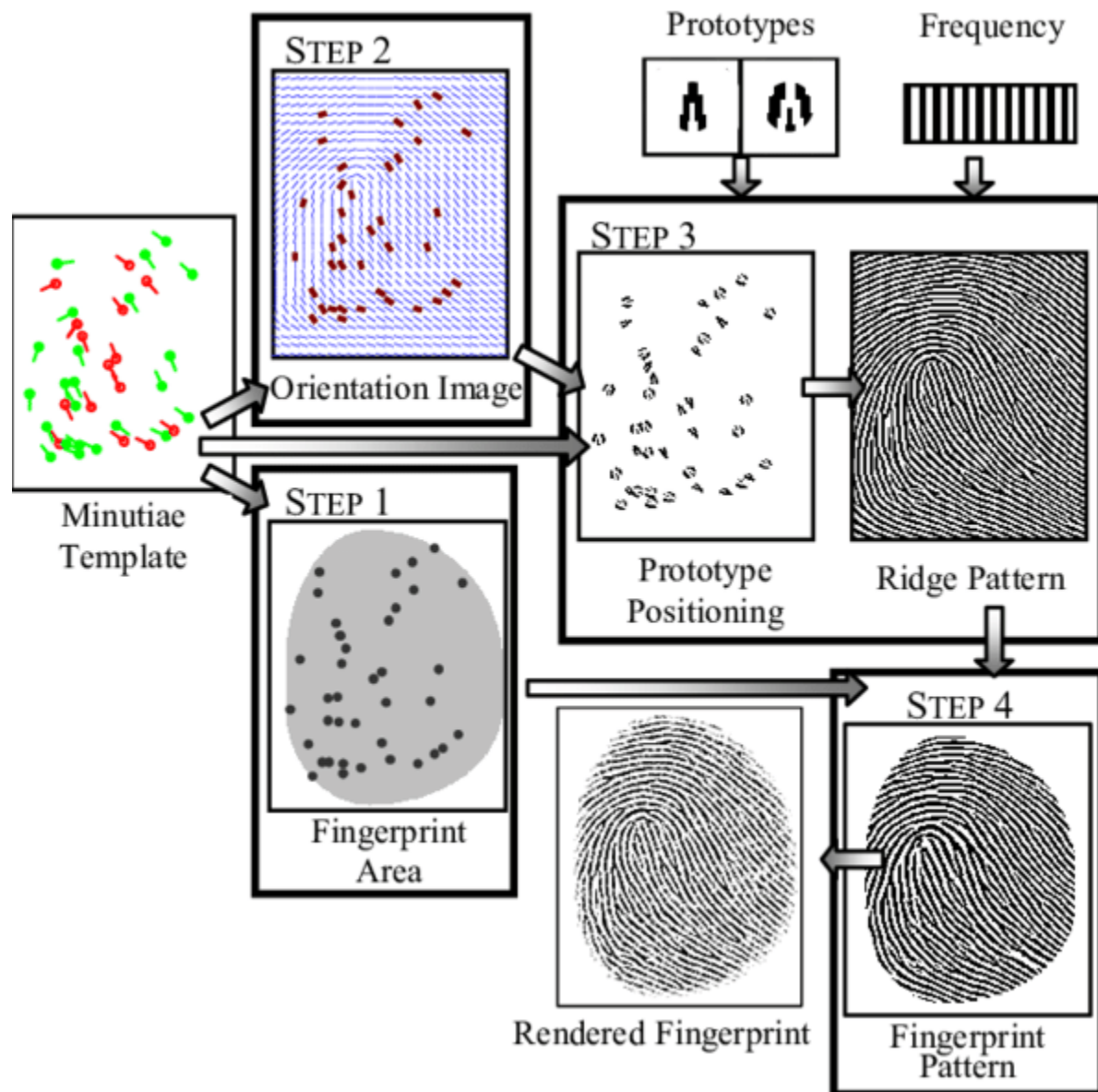


- E' vero che potrebbe aiutare perché **diminuisce la interoperabilità** **MA**:
 - Esistono **template standard e aderenti alle norme ISO**
 - Le società che operano in questo settore sono internazionali (larga scala) e tendono a lavorare **sia per il settore privato sia per il settore pubblico/governativo** con le stesse tecnologie (possibile commistione e passaggio di informazioni)

Template → sample

Non è detto che memorizzare solo i template e non i sample sia abbastanza protettivo per la privacy per un terzo motivo:
esistono esempi di ricreazione (parziale/limitata) dal template → sample.

Utile anche per creare attacchi sul sensore.



In questo esempio il pattern ricostruito è perfettamente compatibile con la lista di minuzie iniziale

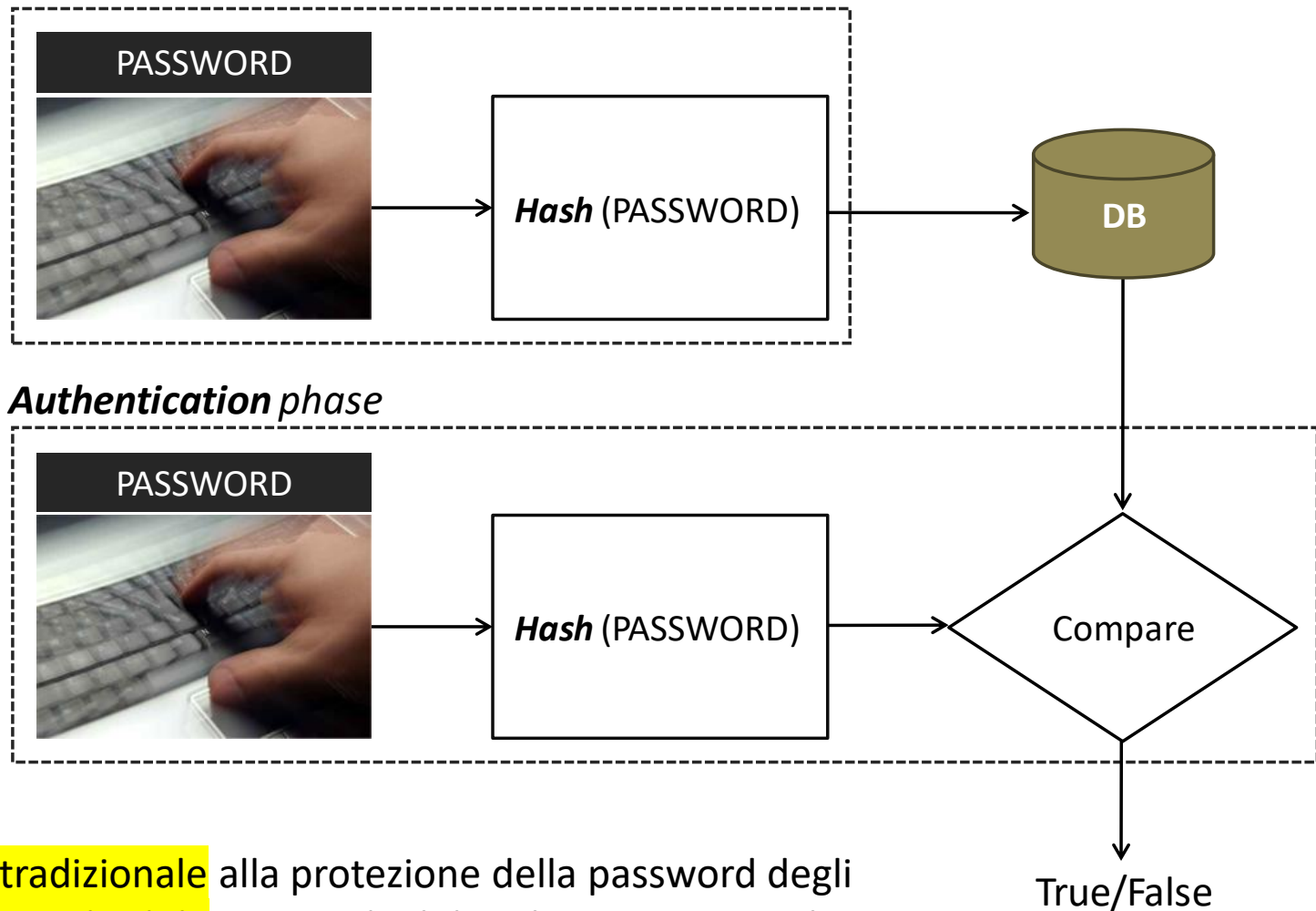


Approcci specifici sul template
biometrico

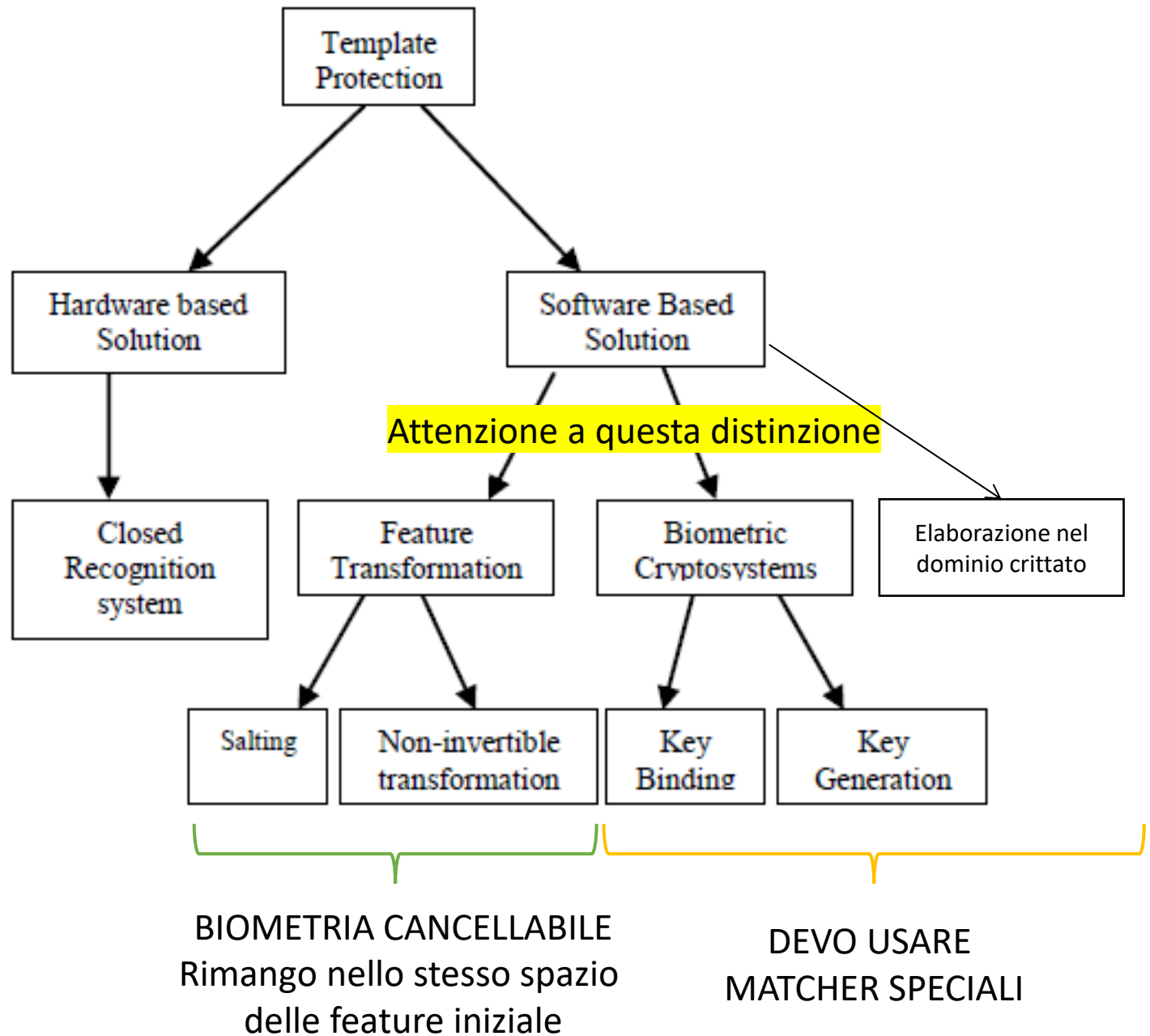
Protezione del template



Classical password protection



L'approccio tradizionale alla protezione della password degli utenti non è applicabile in quando il dato biometrico cambia continuamente (diversamente è un Replay attack!)





Biometria cancellabile

Prima soluzione per la privacy
sul dato

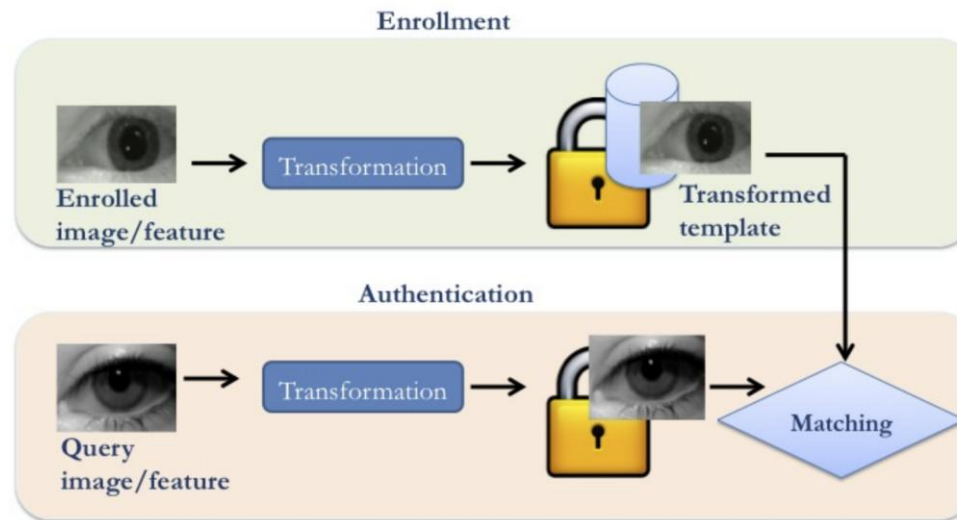


Biometria cancellabile, contesto

- Se rubano
 - la password → la cambio,
 - il token → lo sostituisco.
- Se rubano o copiano la mia impronta, volto, iride ecc. non riesco a cambiarlo!
- La biometria cancellabile è un modo per incorporare la protezione e le funzionalità sostitutive in biometria per creare un sistema più sicuro da questo punto di vista.

Biometria cancellabile: definizione

La **distorsione intenzionale e sistematicamente ripetibile** delle caratteristiche biometriche al fine di proteggere i dati sensibili dell'utente.



ATT! Nella biometria cancellabile devo poter permettere l'uso dello **stesso estrattore di template e matcher** della normale biometria

Biometria cancellabile/rinnovabile: attuazione della protezione

- Se una biometria rinnovabile viene compromessa, le caratteristiche di distorsione vengono modificate e la stessa biometria viene mappata su un nuovo modello, che è usato successivamente.
- Diventa molto più simile a quando
 - Perdo una chiave
→ cambio la serratura
 - Perdo una biometria rinnovabile
→ cambio metodo di deformazione

4 obiettivi principali

- **Diversità**

- Non deve essere usata lo stesso template cancellabile in diverse applicazioni → piuttosto un template cancellabile per ogni applicazione

- **Riusabilità/Revocabilità**

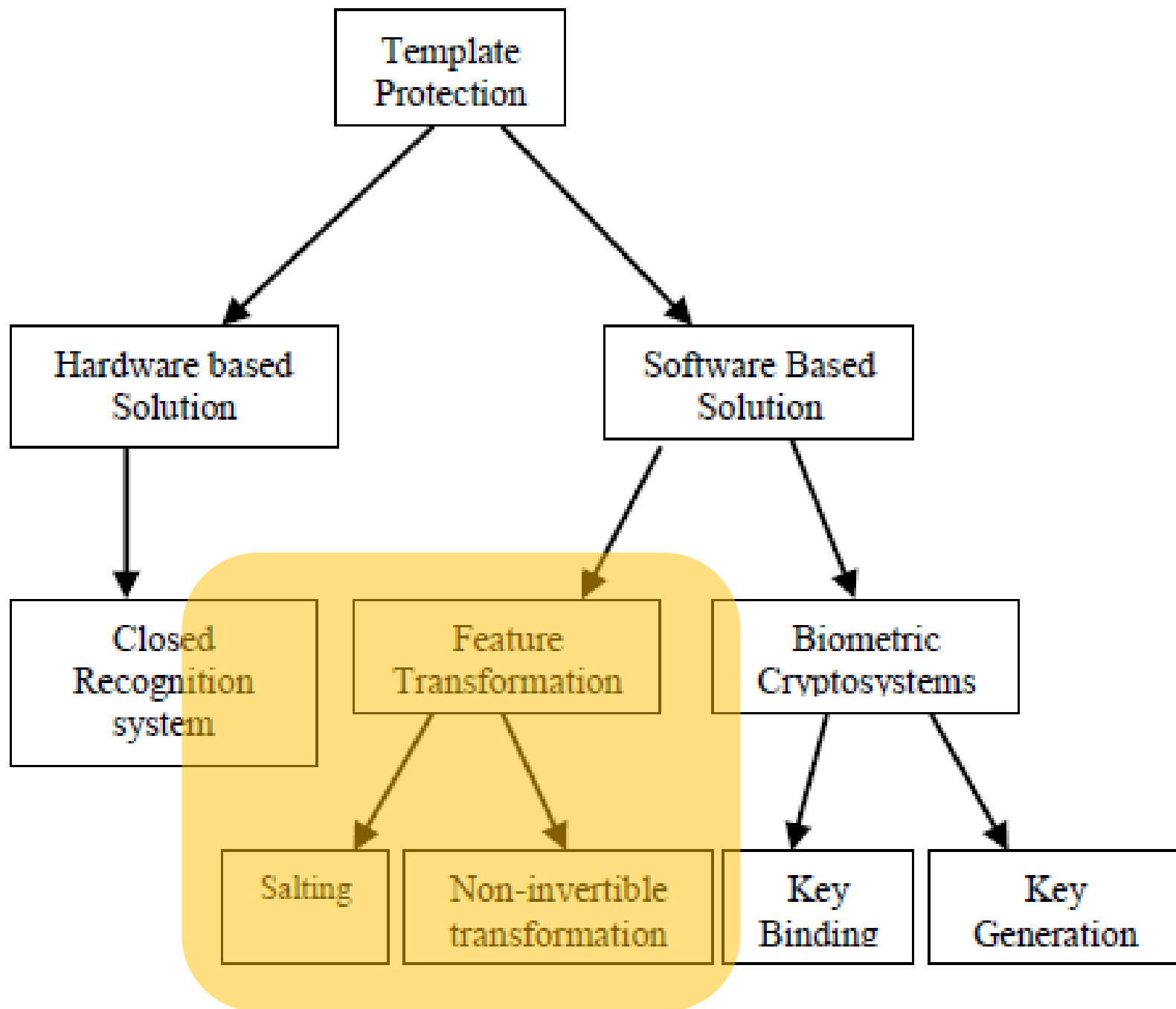
- Deve essere facile ed immediate revocare e creare un nuovo template cancellabile in caso di compromissione

- **Non invertibilità**

- Il template cancellabile non deve essere invertibile al template originale in nessun modo (praticabile)

- **Performance**

- IL metodo utilizzato non deve deteriorare (apprezzabilmente) le performance di riconoscimento (accuratezza)

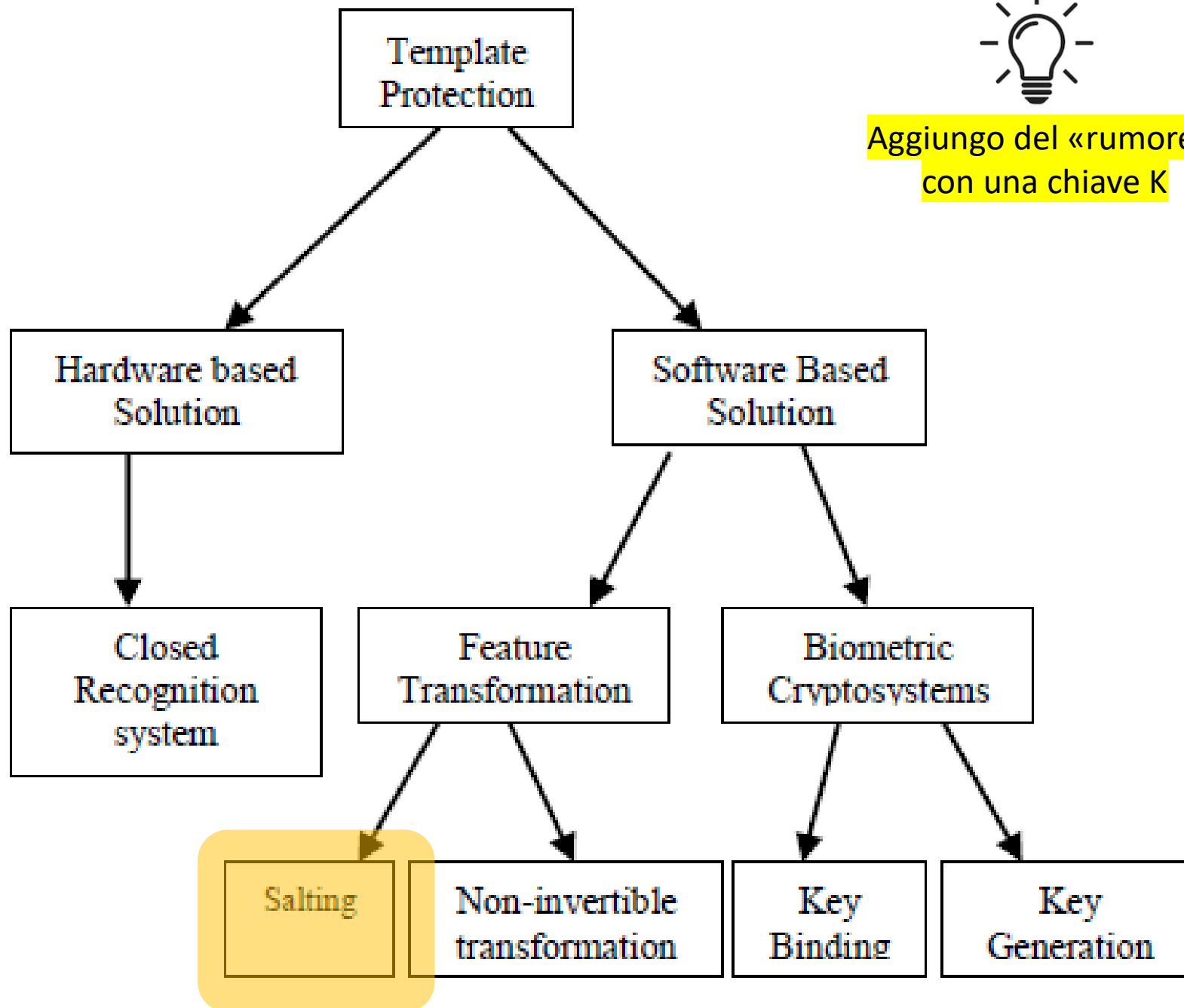


Feature transformation

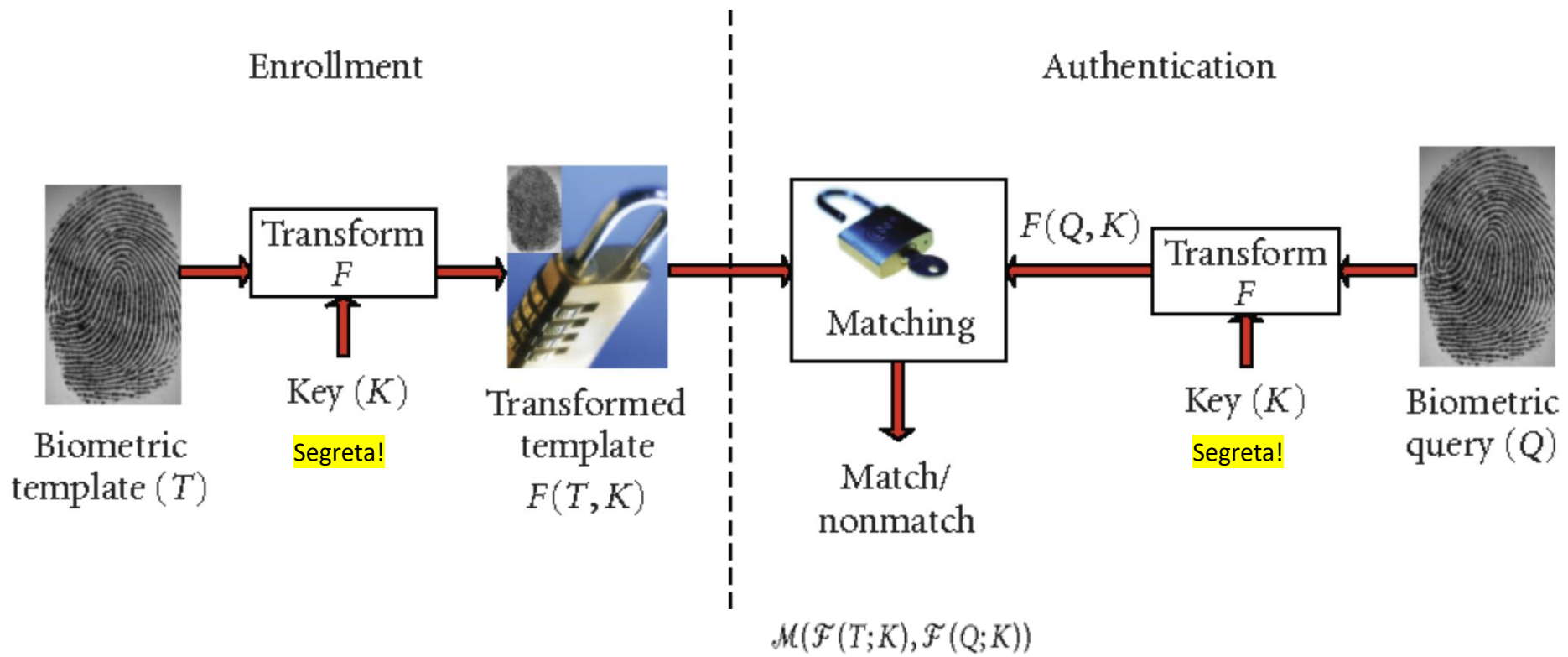
- **Bio-hashing (Salting)**
 - The transformation function is invertible which means the original template can be restored if one can gain access to the key and the transformed template. Hence, the security of the salting scheme is dependent on the key or password.
 - Pensa un numero X , somma K , trasmetti $Y = X + K$. La funzione è somma è invertibile (sottrazione), ma senza la chiave K non posso conoscere X
- **Noninvertible transform.**
 - A one-way function which makes it computationally difficult to invert a transformed template to the original template even if the key is known.
 - Pensa un numero X , trasmetti $Y = F(X)$, ma dato Y e F non sai come tornare a X



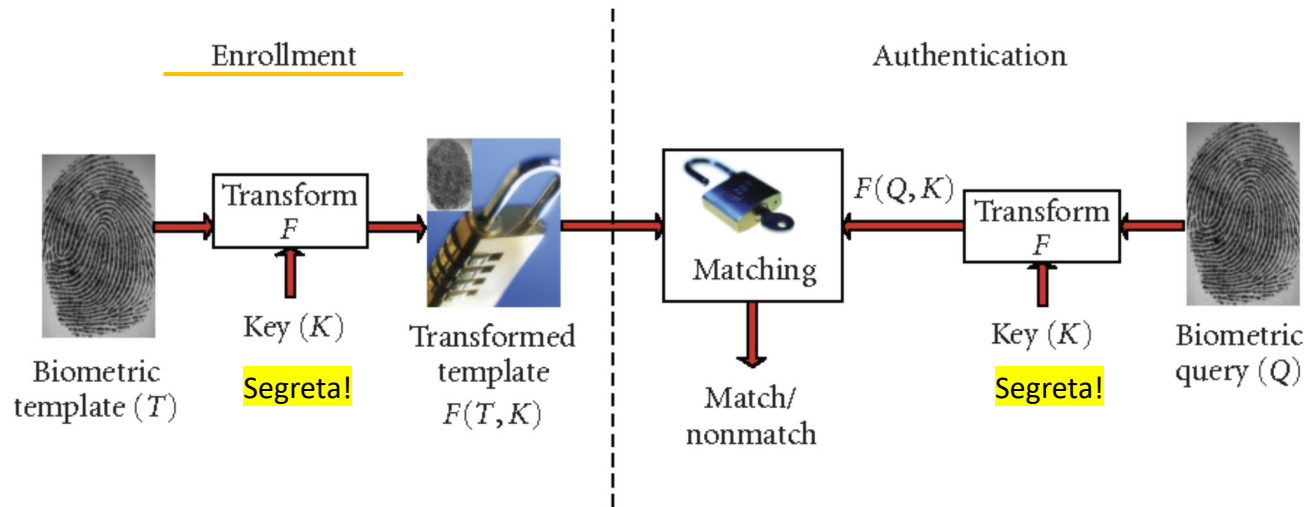
Aggiungo del «rumore»
con una chiave K



Feature transformation: Salting



Problemi del salting

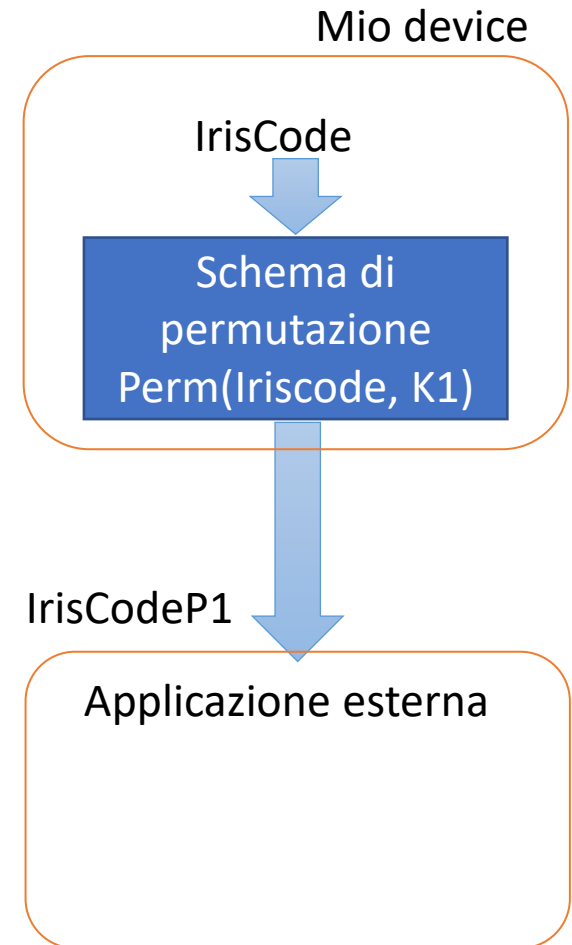


- La funzione $F()$ è invertibile!
Se perdo la chiave K , ho compromesso il sistema perché il mio template memorizzato $F(T, K)$ invertito con K permette di ricavare T (che volevo proteggere...)

Applicazione biometria cancellabile: Permutazioni Iriscode

“se mi rubano il mio Iriscode,
non posso cambiare il mio occhio!”

- **Vero anche che dall'iriscode non si può ricostruire l'iride (completamente....)** ma è possibile operare una trasformazione non facilmente invertibile.
- Partendo dall'Iriscode originale, si possono usare $256! = 10^{507}$ possibili schemi di **permutazione**, facendo diventare di fatto il vecchio Iriscode inservibile. Lo schema si basa su una **chiave privata K**.
- Lo XOR non risente delle permutazioni (→ **stesso matcher classico dell'iriscode!**)



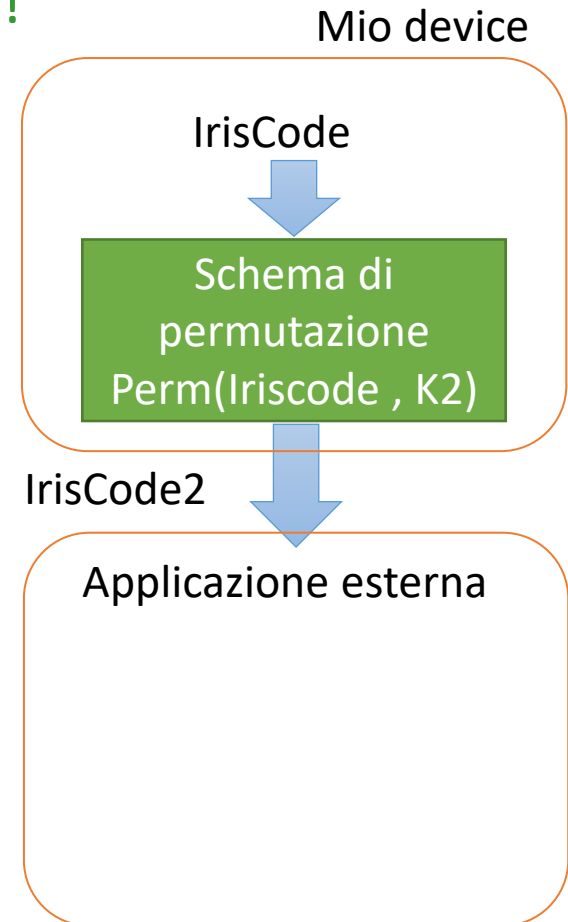
$$\text{XOR}(A, B) = \text{XOR}(\text{Perm}(A, K1), \text{Perm}(B, K1))$$

Applicazione biometria cancellabile: Permutazioni Iriscode₍₂₎

“se mi rubano il mio Iriscode,
non posso cambiare il mio occhio!”

...ma devo tenere
la permutazione segreta

- Ok → allora «mandiamo in giro»
delle permutazioni
- Teniamo anche conto che è
possibile creare Iriscode specifici
o permutati per ogni singola:
 - applicazione
 - sensore
 - intervallo di tempo
 - ecc..



Permutazioni Iriscodes (cont.)

Esempio di un iriscod di 5 bit

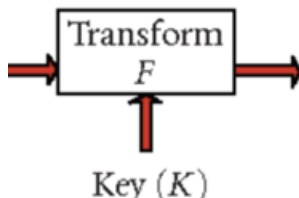
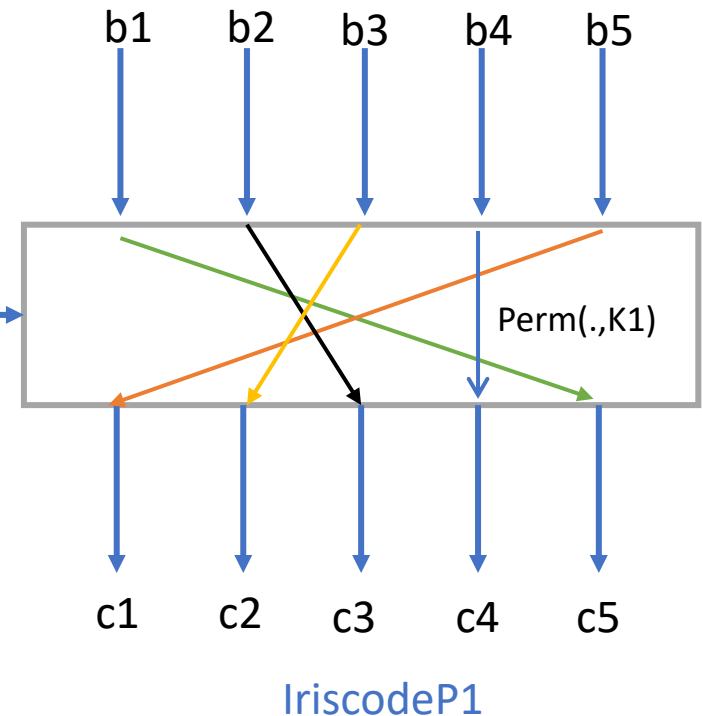
Iriscod = [b1, b2, b3, b4, b5]

K1 = [5, 3, 2, 4, 1] (tenere segreta!)

[c1, c2, c3, c4, c5] = Perm(Iriscod, K1)

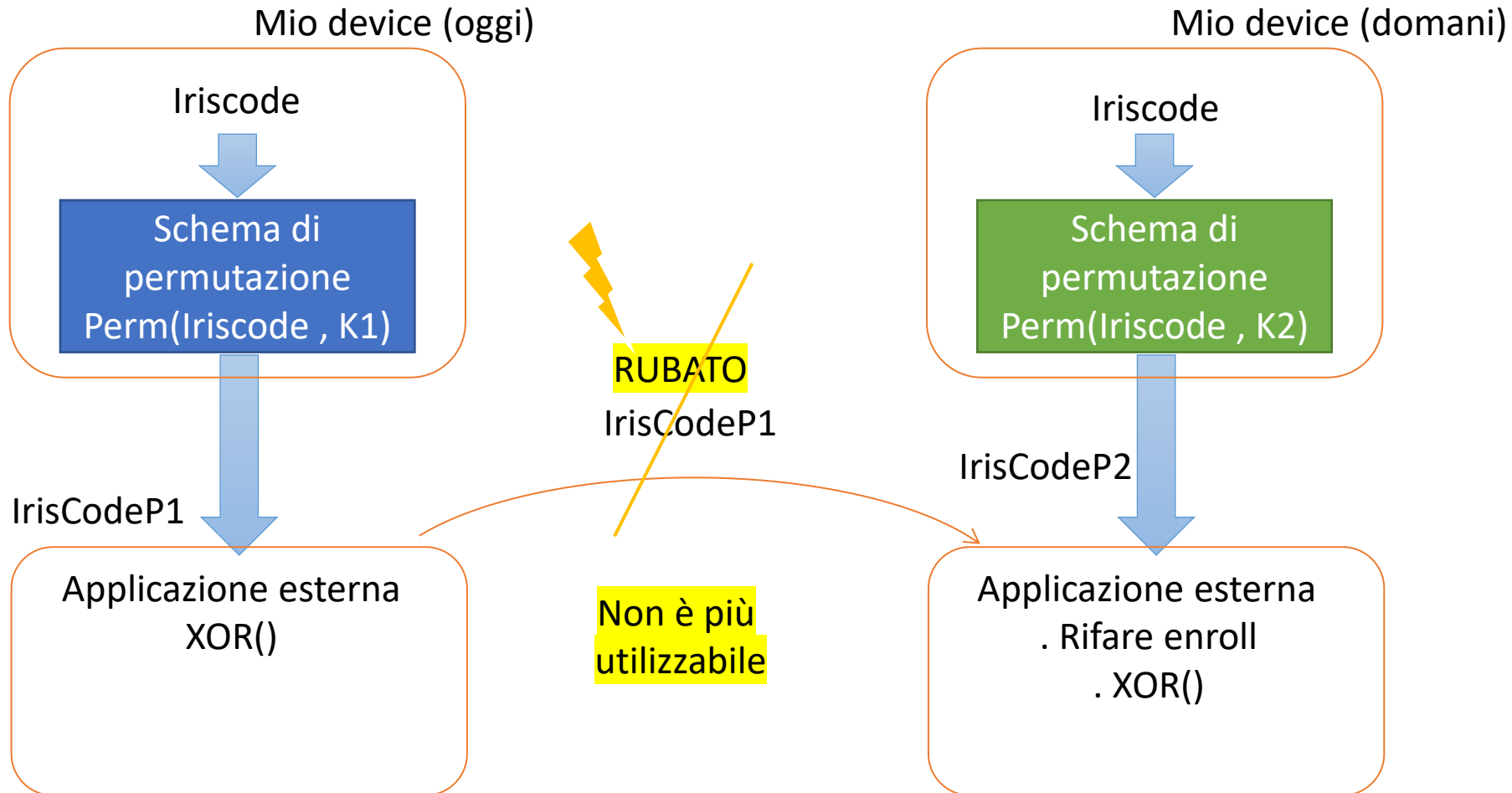
IriscodP1 = [c1, c2, c3, c4, c5]

K1 = [5, 3, 2, 4, 1]



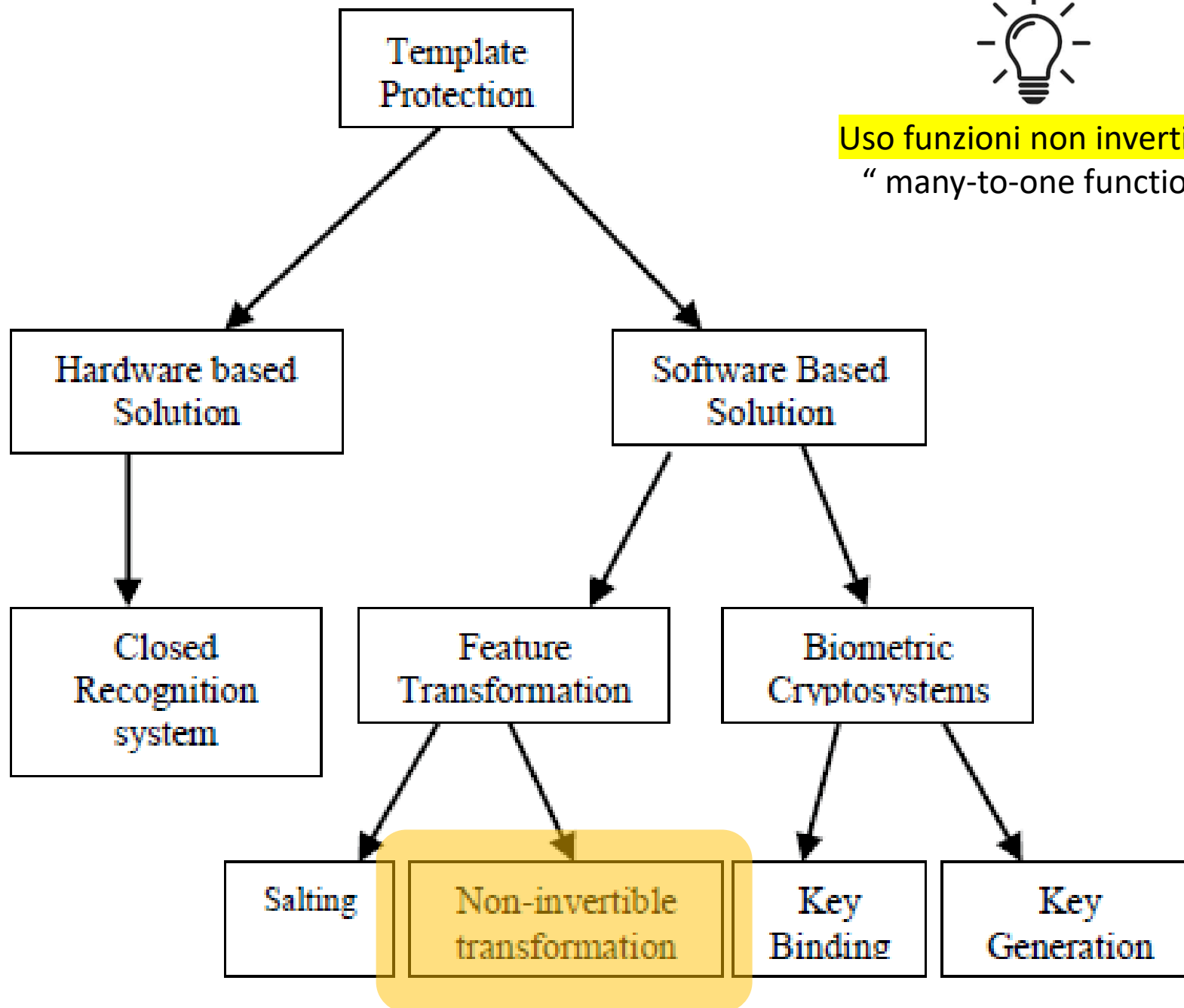
Nota: le correzioni della testa non possono essere più corrette con degli shift dei bit come visto nella lezione dell'iride

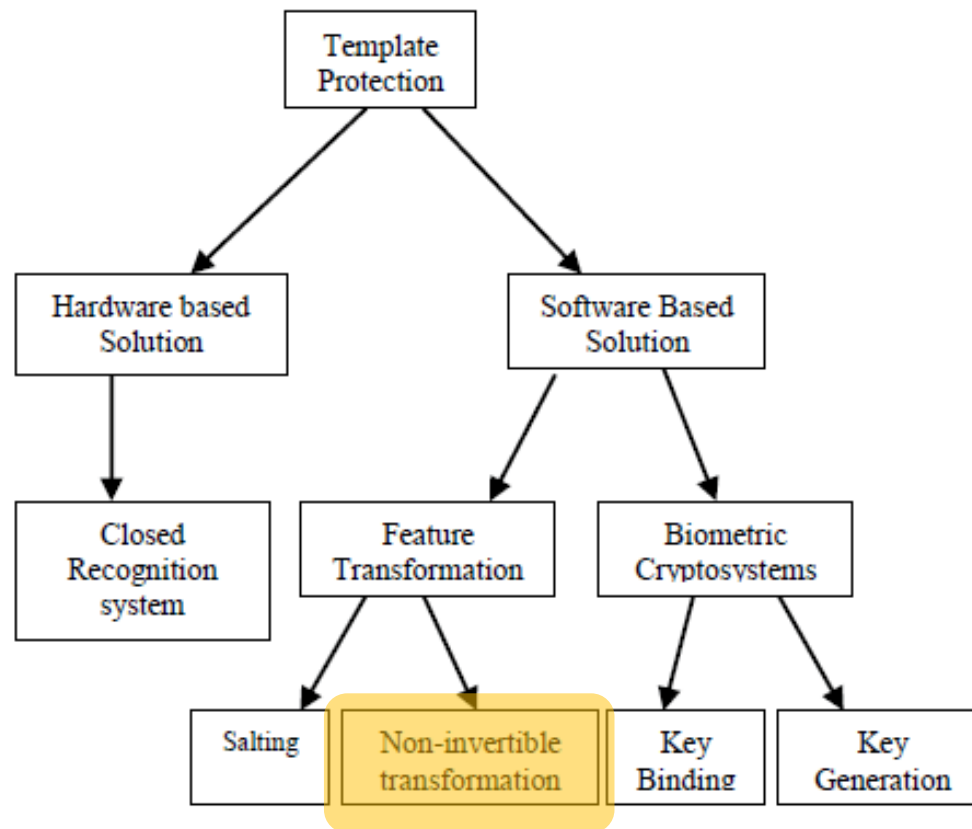
Cambio della Permutazione per protezione da Furto del Template



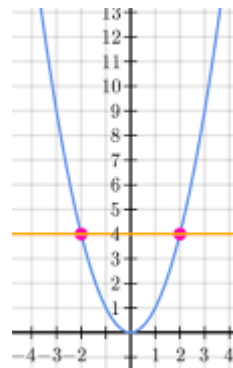


Uso funzioni non invertibili!
“many-to-one function”

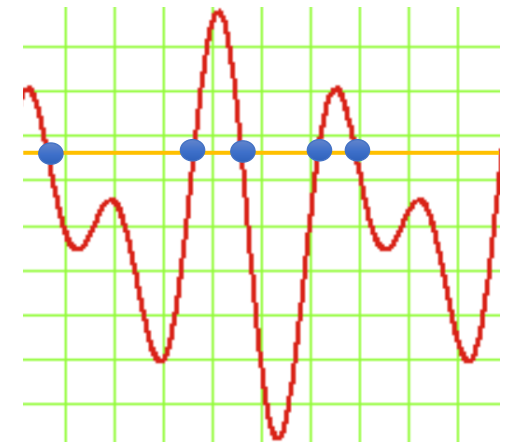




Uso funzioni non invertibili!
 “many-to-one function”



$R \rightarrow R$
Es. $F = x^2$
 $4 = (2^2) ?$
 $4 = (-2^2) ?$
 Se in uscita vedo 4
 non so se è stato
 prodotto dall'ingresso
 $x=2$ o $x=-2$

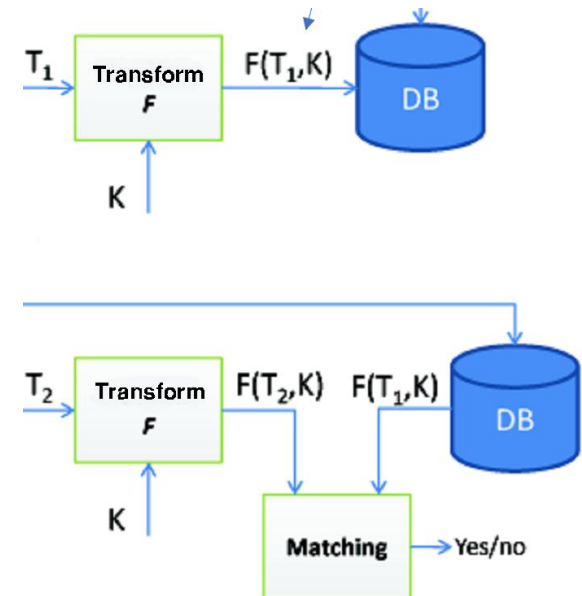


Un semplice polinomio grado $\gg 2$

Trasformazione non invertibile

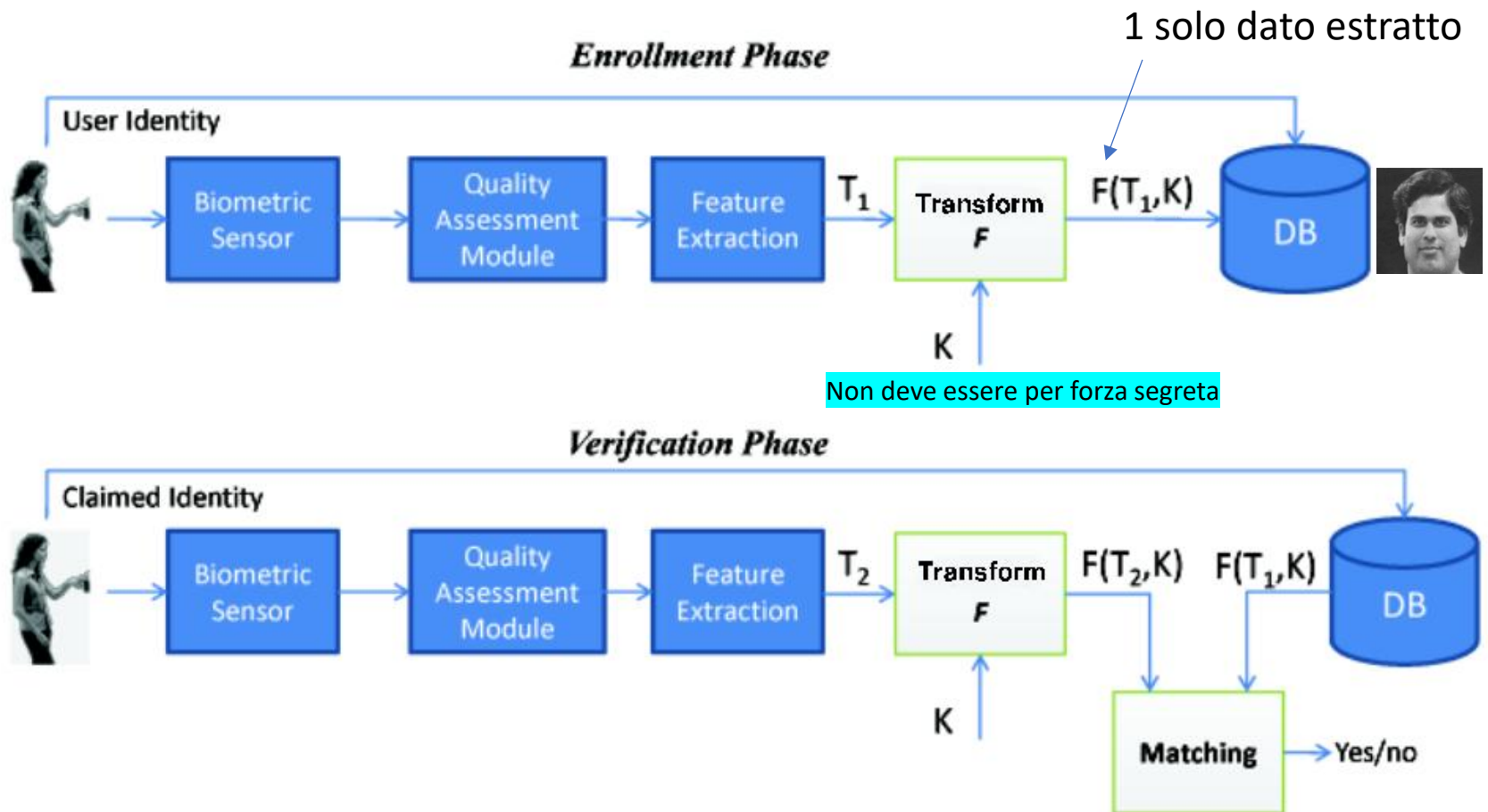
Il modello biometrico acquisito viene trasformato utilizzando una funzione di trasformazione e **solo il modello trasformato viene memorizzato nel database.**

- I parametri della funzione di trasformazione sono generalmente derivati da una chiave o password casuale (es. coeff. di un polinomio)
- La stessa funzione di trasformazione verrà utilizzata anche per trasformare la query e quindi verrà confrontata con il modello trasformato nel database

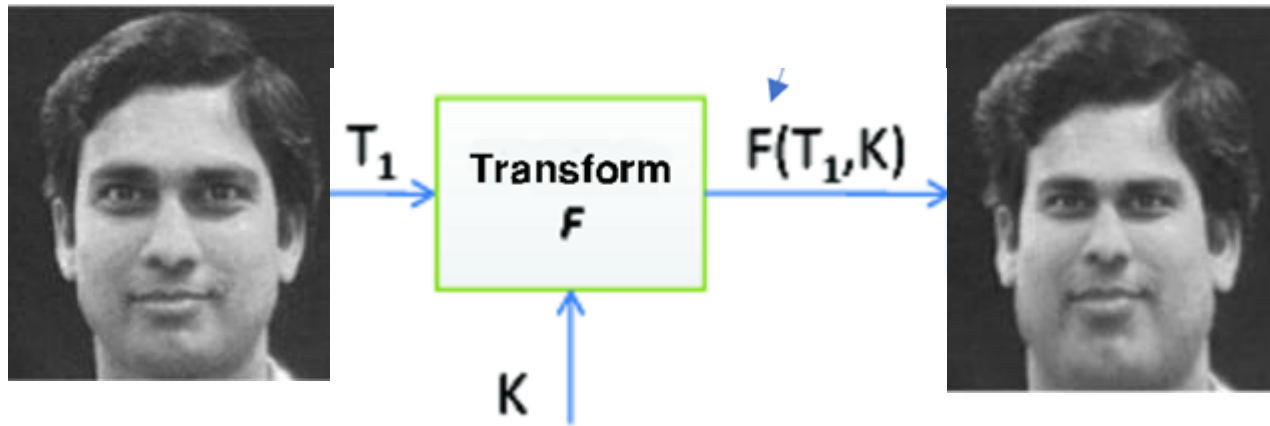


Trasformazione delle feature non invertibile

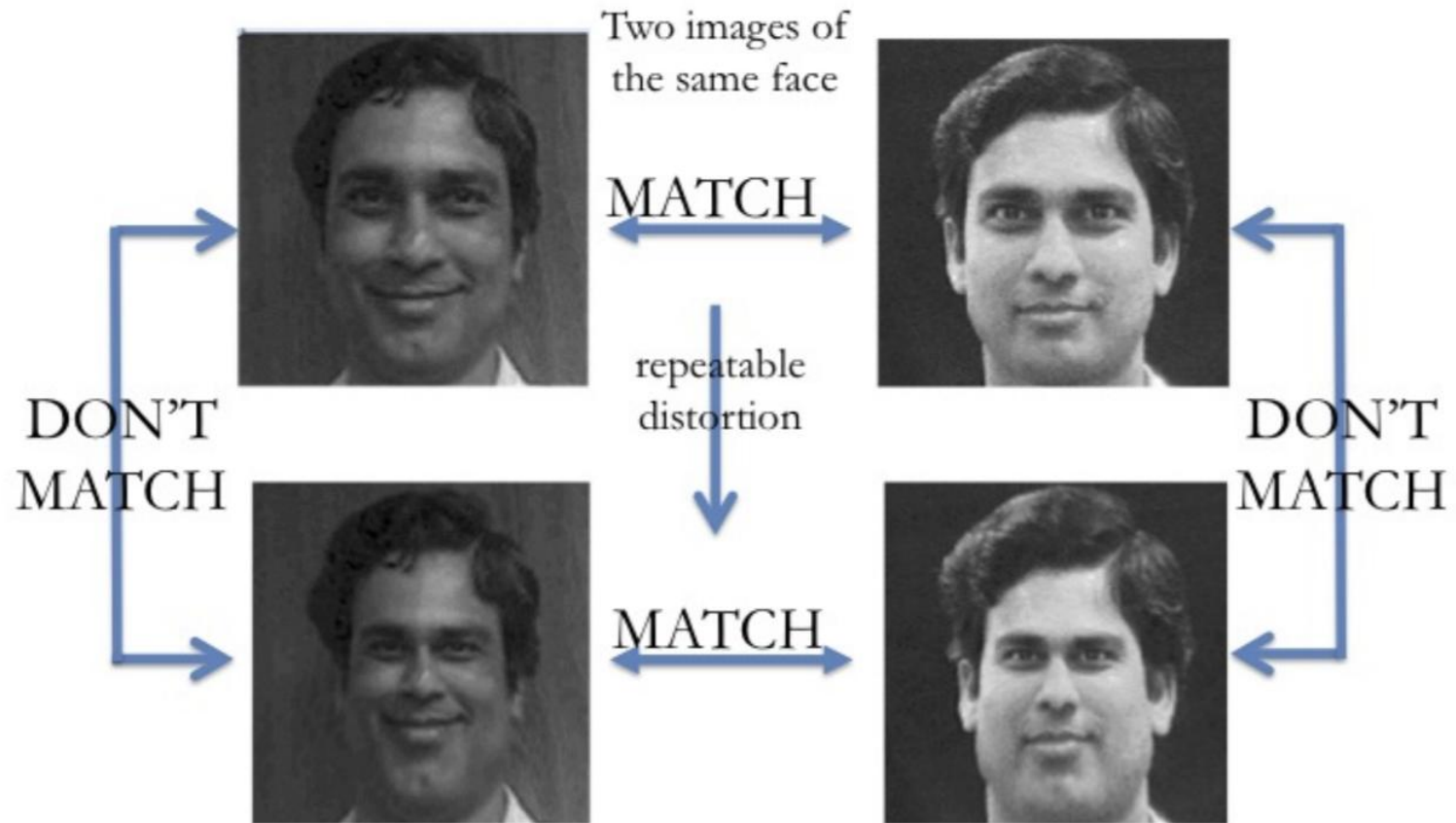
La trasformazione $F(X,K)$ può dipendere anche da una chiave K ora «pubblica»
Con $F()$ e con K non posso tornare a $T1$
“many-to-one function” significa che esistono tantissimi $T1$ che arrivano a $F(T1,K)$!



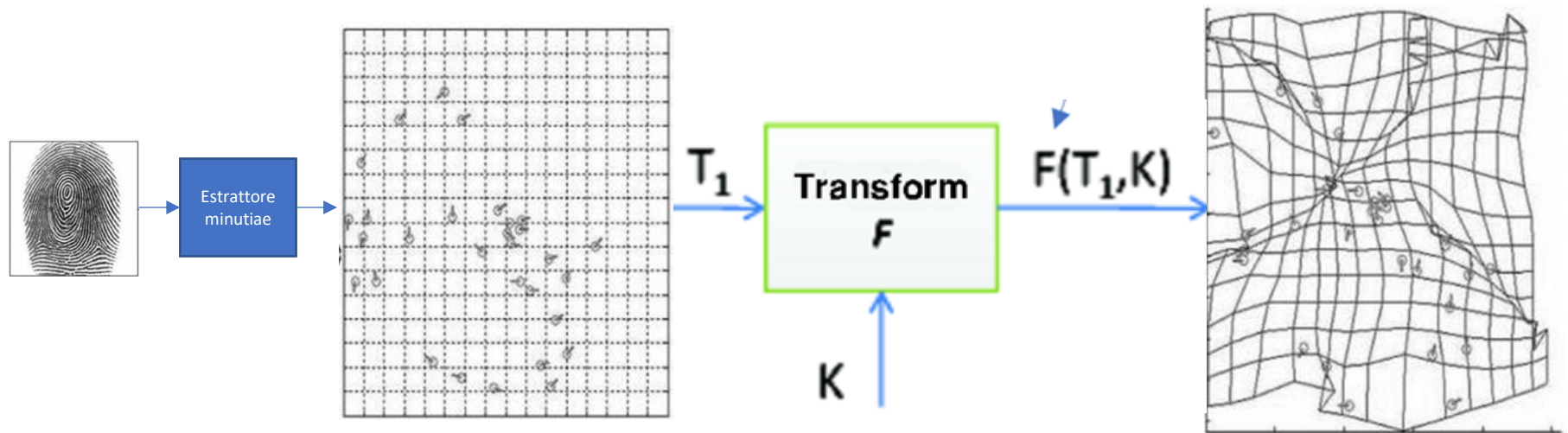
Esempio sul volto morphing non invertibile



Volto: morphing non invertibile



Esempio sulle impronte: deformazione geometrica coordinate minutiae



Funzione **non reversibile**
(altre minutiae in ingresso
possono arrivare negli stessi punti in uscita di $F(T_1, K)$)

Biometric Encryption

Crittosistemi biometrici

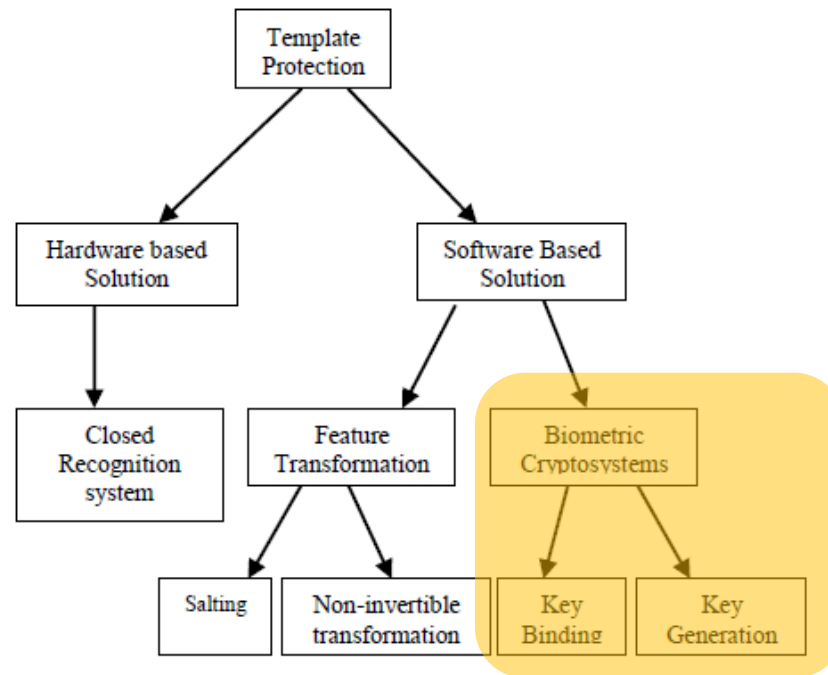
→ il template biometrico deve diventare la chiave
(e funzionare...!)

Approcci di Biometric Encryption (BE)

NOTA:

Rispetto alle tecniche appena viste dove si potevano usare dopo la trasformazione i sistemi biometrici tradizionali, vediamo ora approcci più strutturali e interni al sistema biometrico complessivo.

Necessitano di matcher appositi



Biometric Encryption (BE)

Is a group of emerging technologies that securely

- **bind a digital key to a biometric:**
template = Encrypt[key + biometric]
- or **generate a digital key from the biometric**, Biometric --> [Key]
so that no biometric image or template is stored.

WISH LIST

- It must be computationally **difficult to retrieve either the key or the biometric** from the stored BE template, which is also called “helper data”
- The key will be recreated only if the genuine biometric sample is presented on verification
- The output of the BE authentication
 - is either a key (correct or incorrect)
 - or a failure message

Biometric Encryption: caratteristiche



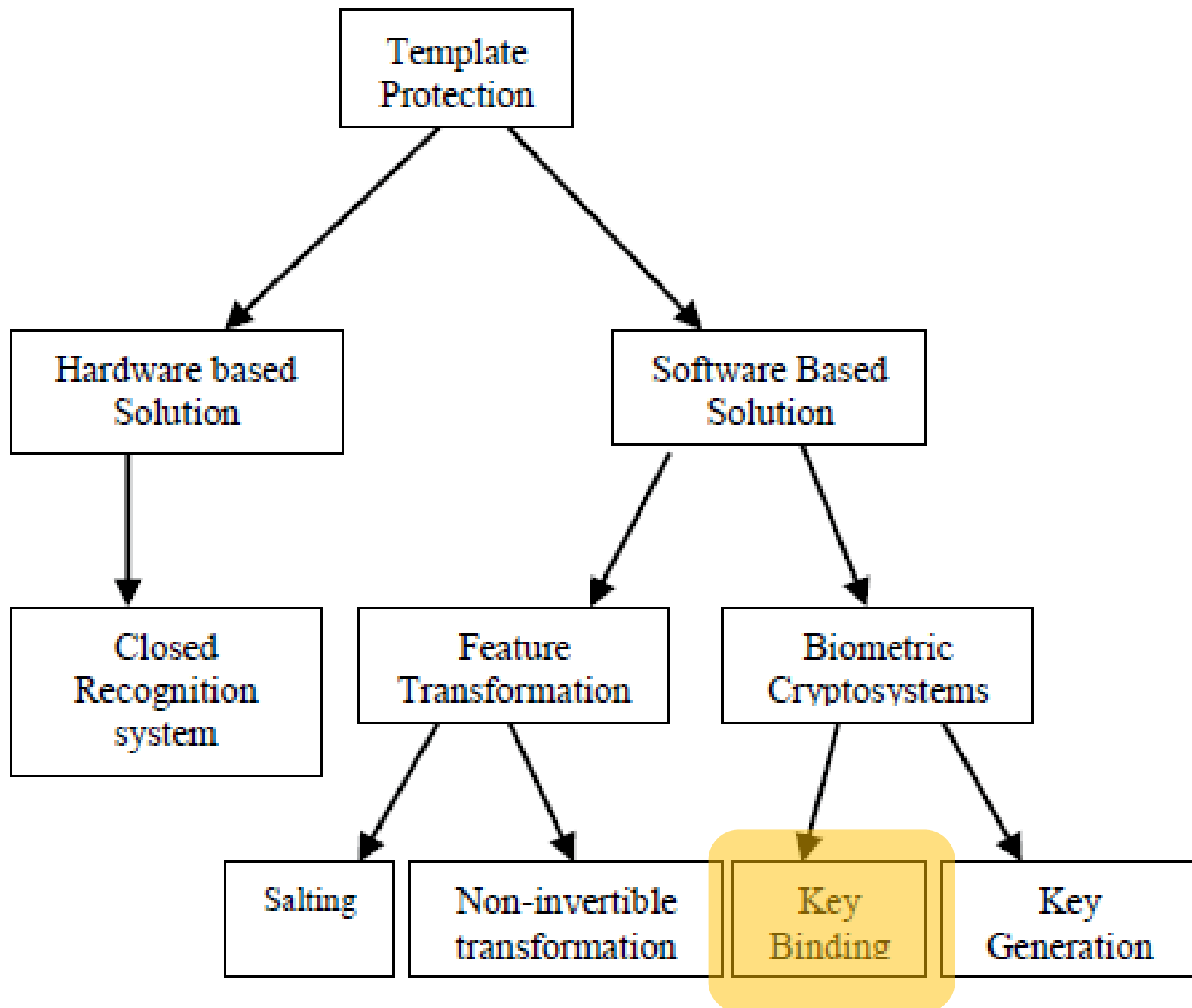
- Unlike conventional cryptography, this “encryption/decryption” process is fuzzy because of the natural variability of the biometrics.
- Biometric Encryption conceptually differs from other systems
 - that encrypt biometric images or templates using conventional encryption
 - or store a cryptographic key and release it upon successful biometric authentication.



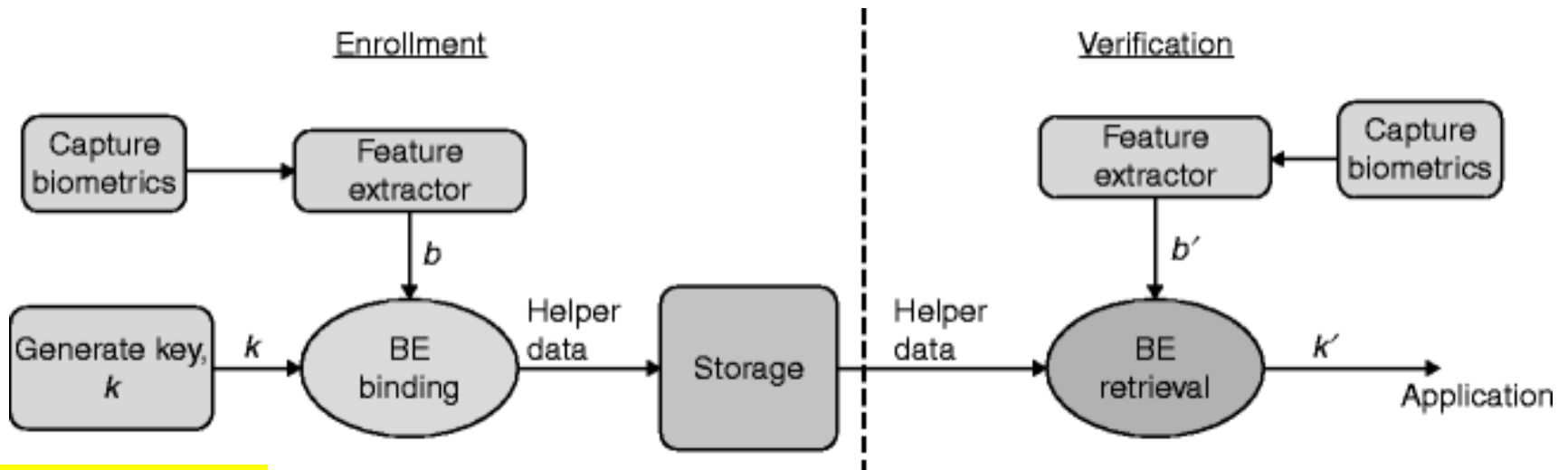
→ KEY
101010101010

Biometric cryptosystem (helper data protection methods)

- Depending on how the helper data is obtained, biometric cryptosystems are further classified into two categories:
 - **key binding**
 - the helper data is obtained by binding a key with the biometric template. It is difficult to obtain either the key or the original template using only the helper data. Hence, security of stored templates is maintained.
 - **key generation systems**
 - the helper data is derived only from the biometric template and the key is generated from the helper data and the query biometric features.
- When more template protection approaches are used, it is known as **hybrid template protection scheme**



Key Binding



Serve un chiave k

La chiave k è legata ad una trasformazione del template b con un codice di correzione errori creando l'Helper data

“Helper” perché:

aiutano la ricostruzione

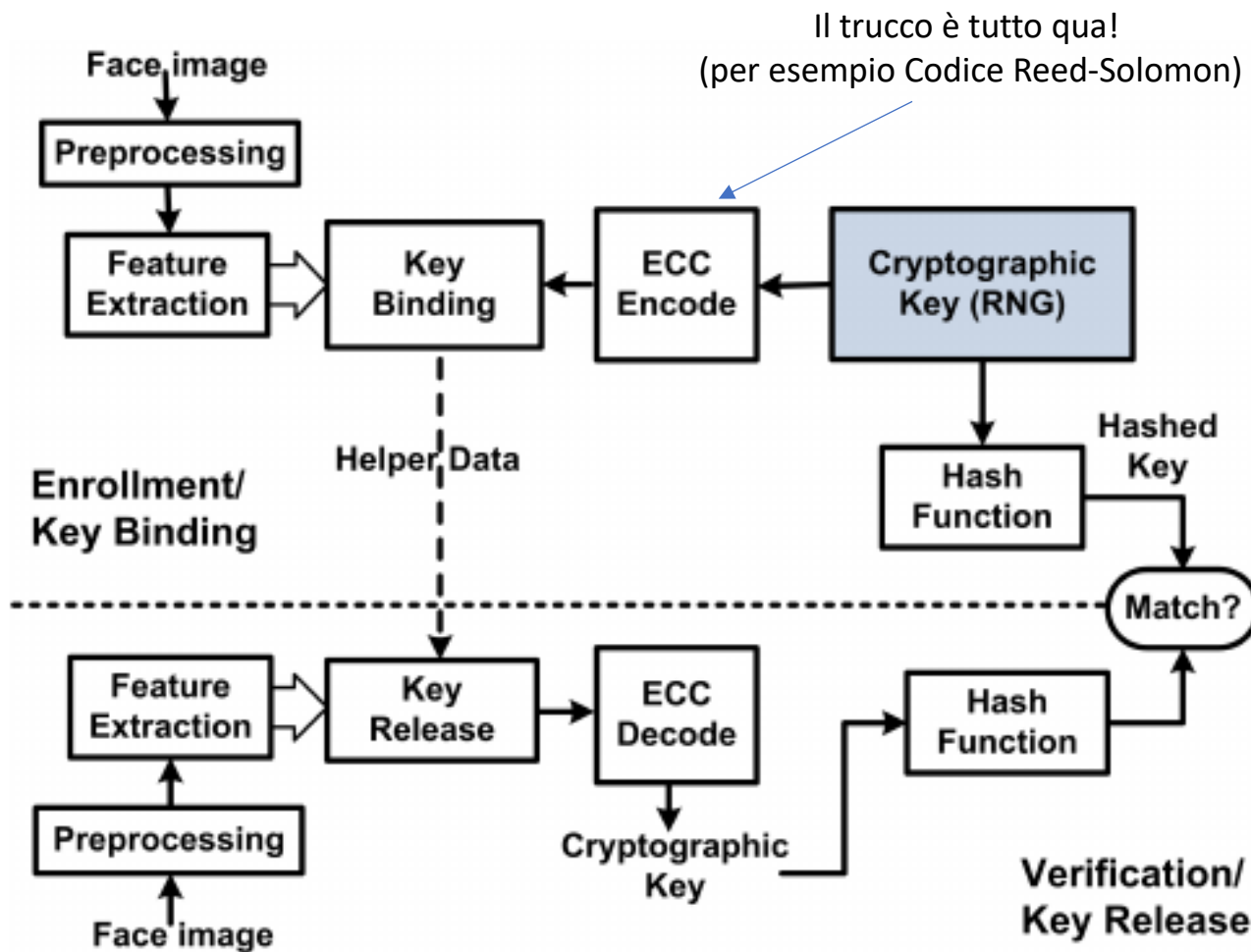
non contengono l'informazione sensibile

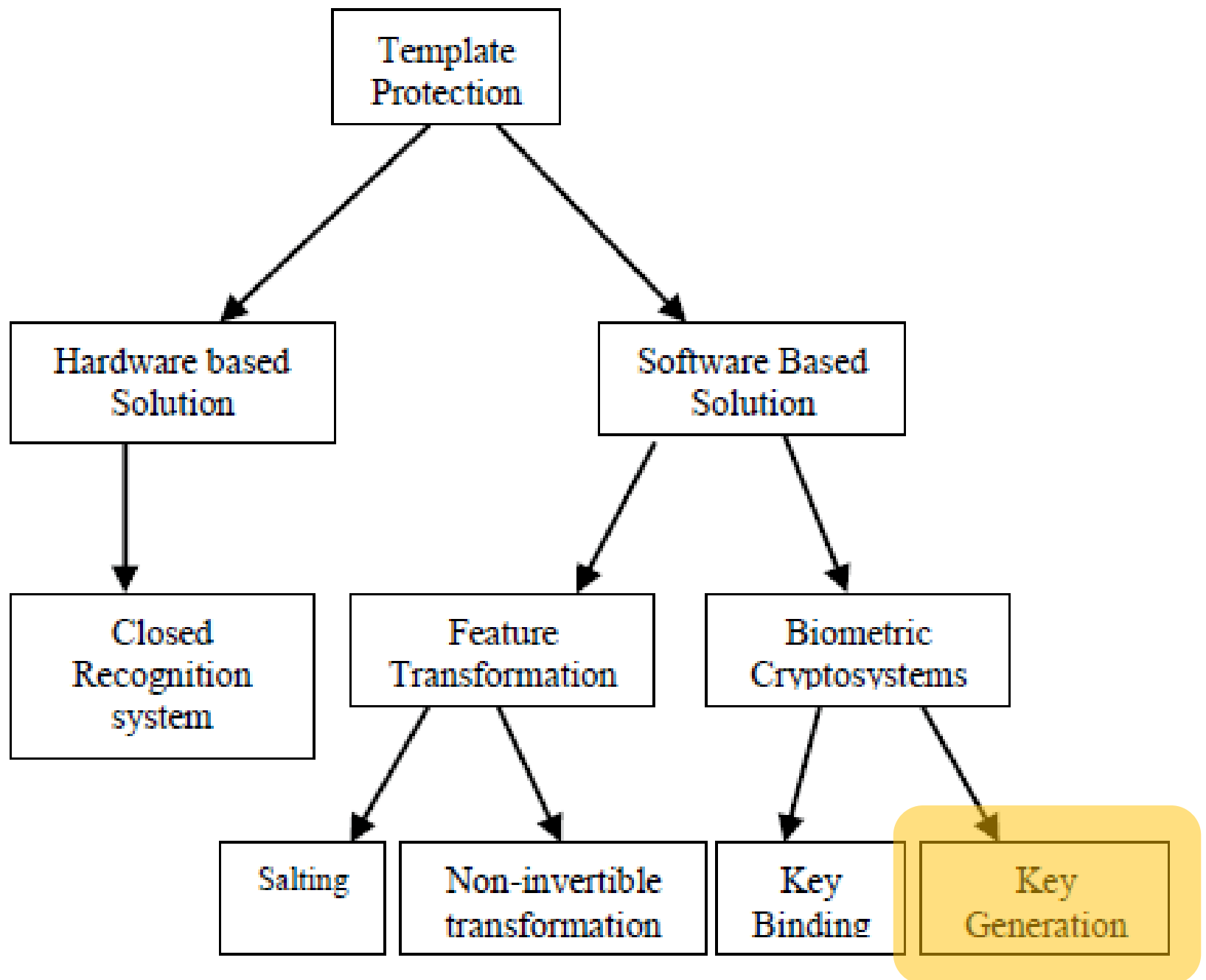
non sono segreti in senso crittografico

Se in verifica arriva un template abbastanza simile, l'estrattore riesce a creare un codice b' che permette di ricostruire la chiave dall'Helper data, altrimenti fallisce cioè k' diverso da k

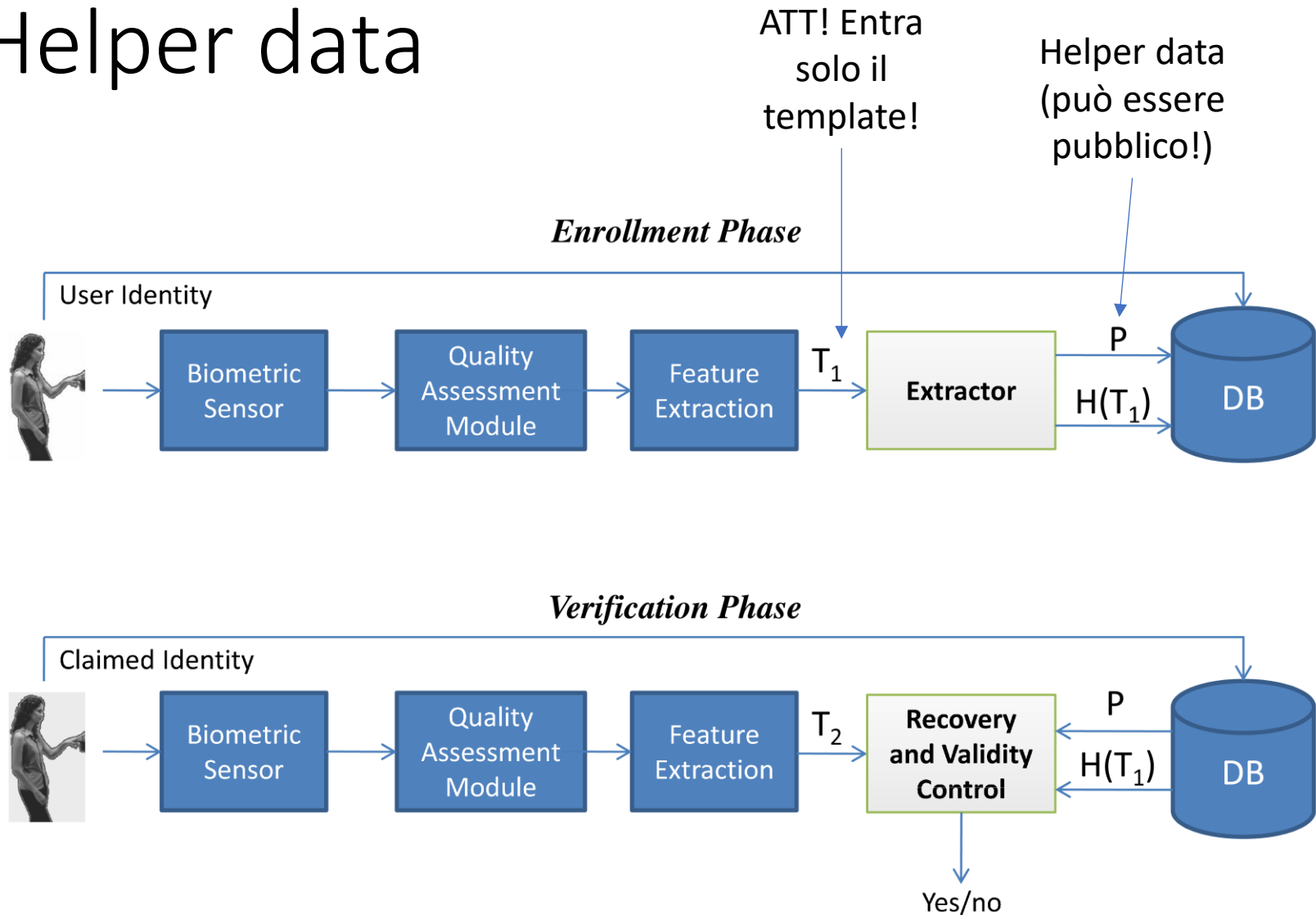
Per sapere se abbiamo indovinato la chiave si memorizza in chiaro Hash(k)

Esempio di schema completo di key binding (non all'esame)





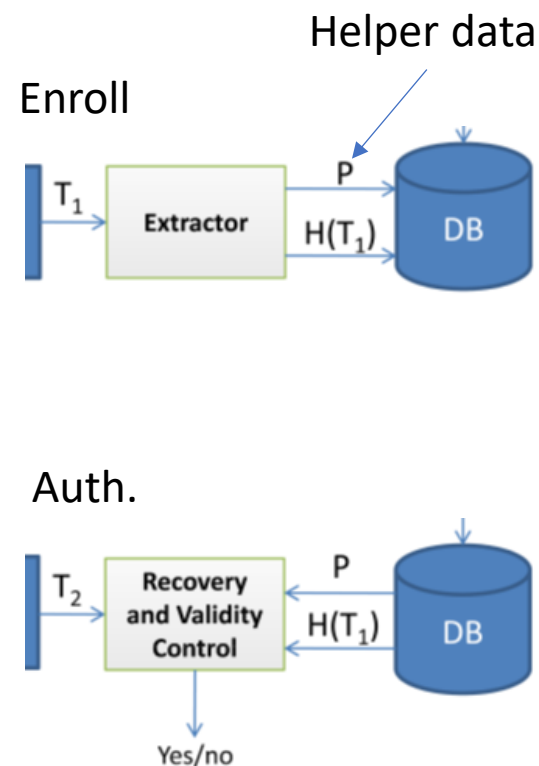
Helper data



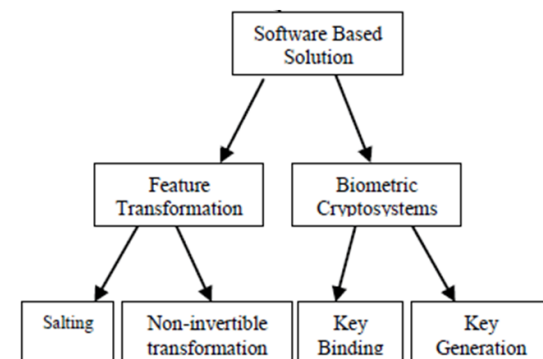
Notare che qui non serve una chiave esterna!

Biometric cryptosystem (helper data protection methods)

- In this case the helper data is stored. Helper data is some public information about the biometric template and does not reveal any significant information about the stored template
- The helper data is required to extract a cryptographic key from the query biometric template and then matching is performed indirectly by verifying the validity of the extracted cryptographic key
- Error coding techniques will be typically used to handle the intruder variations (e.g. Reed-Solomon)



Riassunto dei metodi di protezione standard



Approach	What imparts security to the template?	What entities are stored?	How are intrauser variations handled?
Salting	Secrecy of key K	Public domain: transformed template $\mathcal{F}(T; K)$ Secret: Key K	Quantization and matching in transformed domain $\mathcal{M}(\mathcal{F}(T; K), \mathcal{F}(Q; K))$
Noninvertible transform	Noninvertibility of the transformation function $\mathcal{F}$	Public domain: transformed template $\mathcal{F}(T; K)$, key K	Matching in transformed domain $\mathcal{M}(\mathcal{F}(T; K), \mathcal{F}(Q; K))$
Key-binding biometric cryptosystem	Level of security depends on the amount of information revealed by the helper data H	Public domain: helper data $H = \mathcal{F}(T; K)$	Error correction and user specific quantization $K = \mathcal{M}(\mathcal{F}(T; K), Q)$
Key-generating biometric cryptosystem	Level of security depends on the amount of information revealed by the helper data H	Public domain: helper data $H = \mathcal{F}(T)$	Error correction and user specific quantization $K = \mathcal{M}(\mathcal{F}(T), Q)$

Altre tecniche di protezione della privacy dei template biometrici

- Feature transformation
- Helper data approach
- Fuzzy commitment
- Fuzzy vault
- Secure sketch
- Fuzzy extractor
- Pin-Sketch
- Bio-hashing
- Revocable bio-token
- Biotope
- Bio-Encryptor

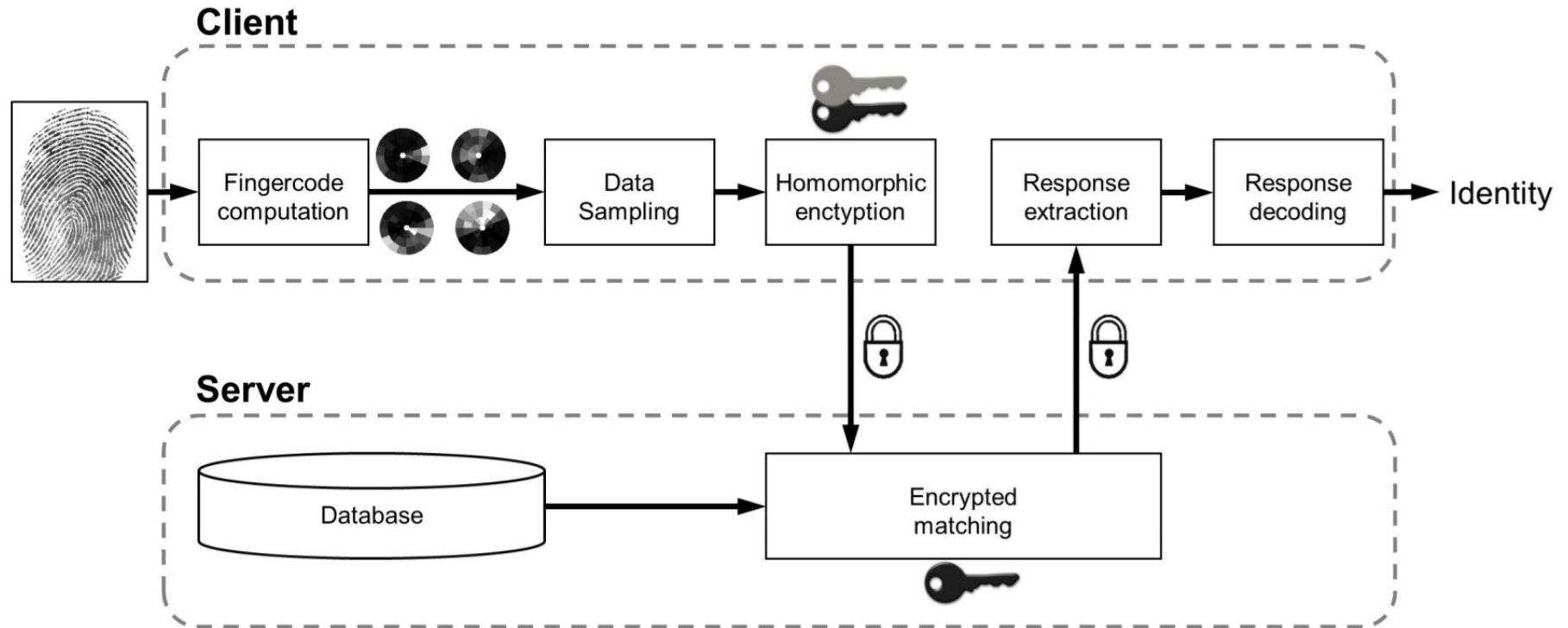
BIOMETRIC

ENCRYPTION



Elaborazione biometrica
nel dominio crittato

Elaborazione del dominio crittato (il server non sa cosa sta facendo)



- Solo operazioni come somme, differenze, moltiplicazioni e soglie fra valori effettivamente possibili → si possono fare matching piuttosto semplici.
- Recentemente si è fatta la prima CNN (estesa, ma semplice..)

Dispensa su questi temi

Biometric Privacy Protection: Guidelines and Technologies

Ruggero Donida Labati, Vincenzo Piuri, and Fabio Scotti

Università degli Studi di Milano, Department of Information Technology,
via Bramante 65, I-26013 Crema (CR), Italy
{[ruggero.donida](mailto:ruggero.donida@unimi.it),[vincenzo.piuri](mailto:vincenzo.piuri@unimi.it),[fabio.scotti](mailto:fabio.scotti@unimi.it)}@unimi.it
<http://www.dti.unimi.it>

Abstract. Compared with traditional techniques used to establish the identity of a person, biometric systems offer a greater confidence level that the authenticated individual is not impersonated by someone else. However, it is necessary to consider different privacy and security aspects in order to prevent possible thefts and misuses of biometric data. The effective protection of the privacy must encompass different aspects, such as the perceived and real risks pertaining to the users, the specificity of the application, the adoption of correct policies, and data protection methods as well. This chapter focuses on the most important privacy issues related to the use of biometrics, it presents actual guidelines for the implementation of privacy-protective biometric systems, and proposes a discussion of the methods for the protection of biometric data.

Keywords: Biometrics - Privacy - Security - Template protection.

1 Introduction

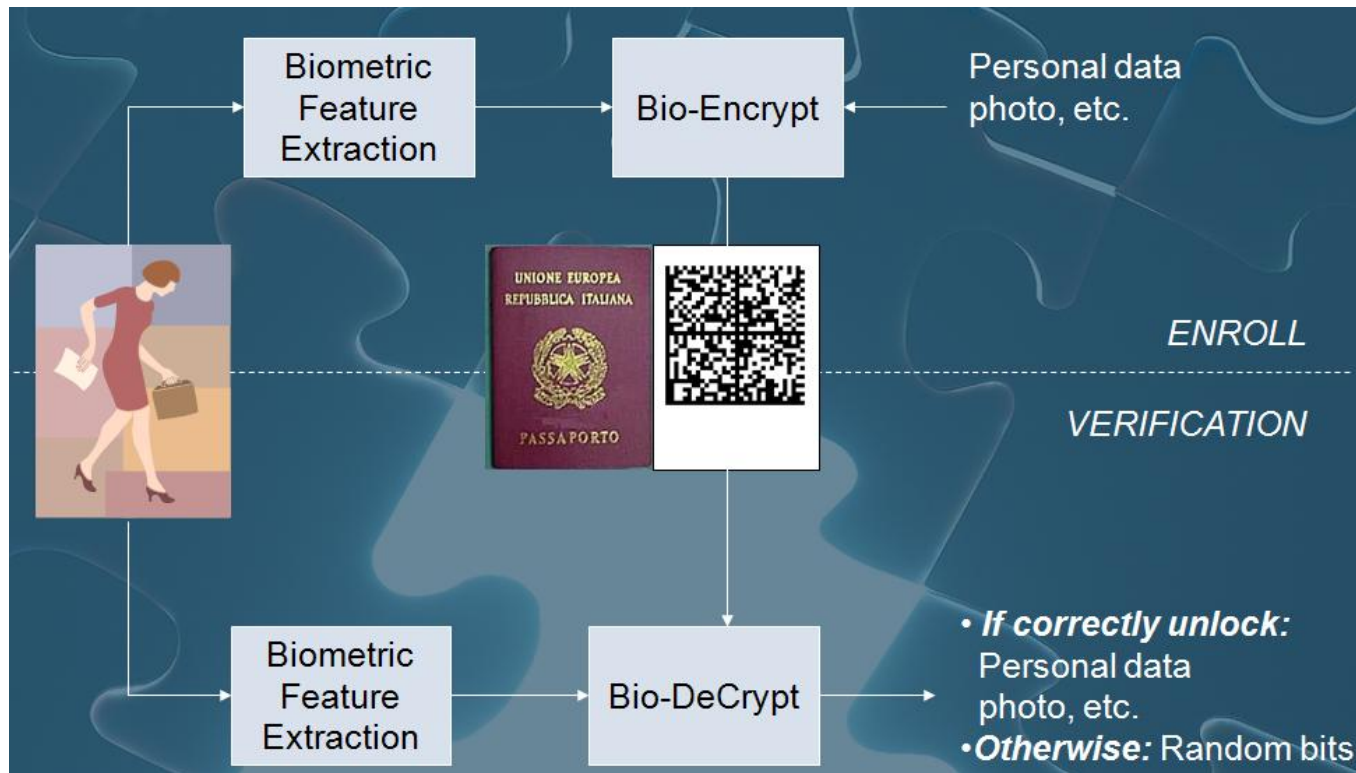
Traditional techniques used to establish the identity of a person are based on surrogate representations of his/her identity, such as passwords, keys, tokens, and identity cards. In many situations, these representations cannot guarantee a sufficient level of security because they can be shared, misplaced or stolen. Biometric recognition systems, instead, are based on physiological or behavioral characteristics of the individual, which are univocally related to their owner, cannot be shared or misplaced, and are more difficult to be stolen. The use of biometric systems is continuously increasing in different applicative scenarios [46] and the related market is showing a significant positive trend. In 2011, it reached the amount of 5 billion dollars and it is expected to reach 12 billion dollars by the end of 2015 [1]. Typical applicative scenarios are: physical access control (critical areas, public buildings, sport arenas, bank caveau, transportations, etc.); surveillance (private buildings, public areas, etc.); government applications (identity cards, passports, driving licenses, immigration control, health cards, access control to online government services, etc.); forensic applications (body identification, crime investigation, searching of disappeared childrens, kinships,

Esempi avanzati di trasformazioni

Per la protezione dei template

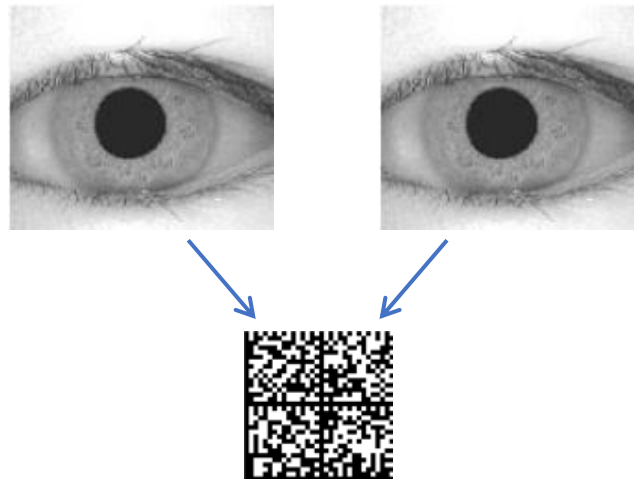
Come usare la biometria come chiave crittografica

OBIETTIVO: generare un identificativo combinando tratti biometrici in un modo che rende impossibile ritornare ai template biometrici originali (e quindi preservando la privacy degli utenti)



Un esempio di possibile soluzione IrideSX+IrideDX

- Crea un'identificazione biometrica cifrando **l'occhio destro** utilizzando **l'occhio sinistro**.
Senza il permesso dell'utente, i dati biometrici non possono essere utilizzati.



Idea: “critto” un occhio con l’altro

Semplificando molto, l’idea e’ la seguente

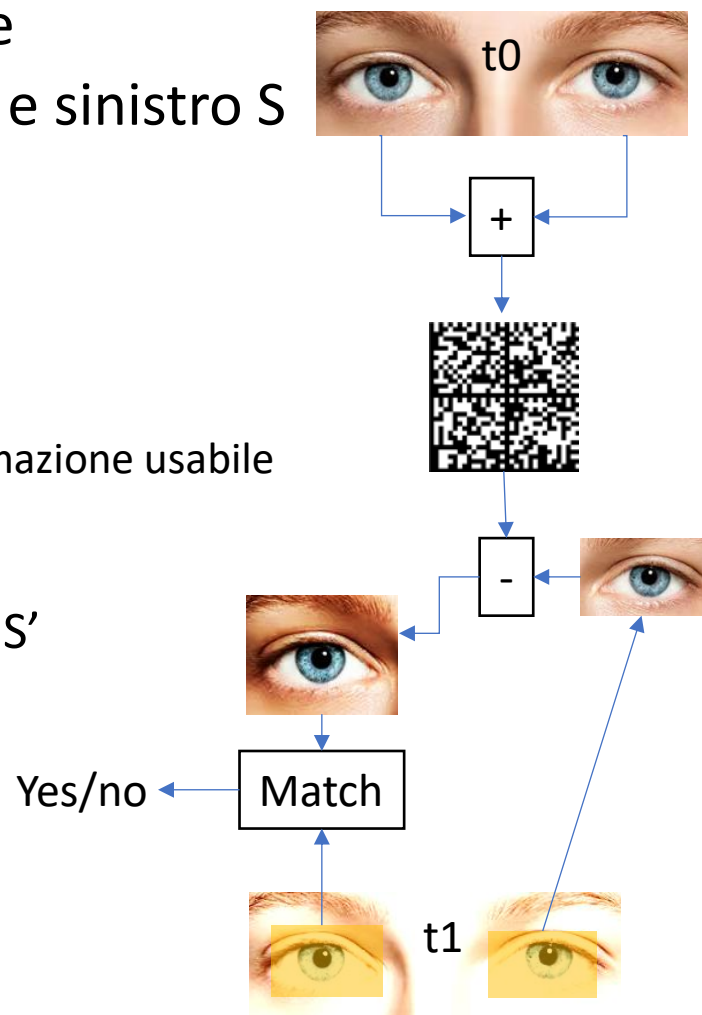
1 Ottengo l’iris code del l’occhio destro D e sinistro S

2 Enroll

- Il template T possiamo immaginarlo come
 $T = D + S$
- Proprietà di T
 - T e’ un mix non reversibile di D e S.
 - Senza conoscere D e S non ho nessuna informazione usabile dell’utente

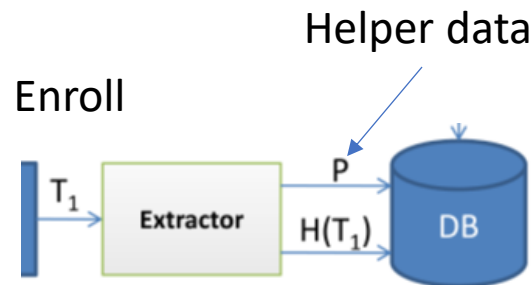
3 Verifica

- Acquisisco dal sensore il nuovo sample D’ e S’
- Sottraggo al template T l’iride S’
 $T - S' = (D + S) - S' \approx D$
Essendo S’ molto simile a S
- Verifica la distanza fra $((D + S) - S) = ? D'$



Contesto: biometric cryptosystem (helper data protection methods)

- Al posto che usare un solo sample biometrico come descritto prima



- Qui useremo lo stesso tratto biometrico, ma due sample indipendenti: occhio SX e occhio DX

IrideSX+IrideDX

Enroll

Lo schema è un esempio, non è richiesto all'esame

Iris code lungo

I_1

Iris code corto

I_2

Pseudo-Random
Permutation

Error Correction
Encoding

Hash Function

δ

$H(I_2)$

$\{H(\cdot), \delta\}$

ID

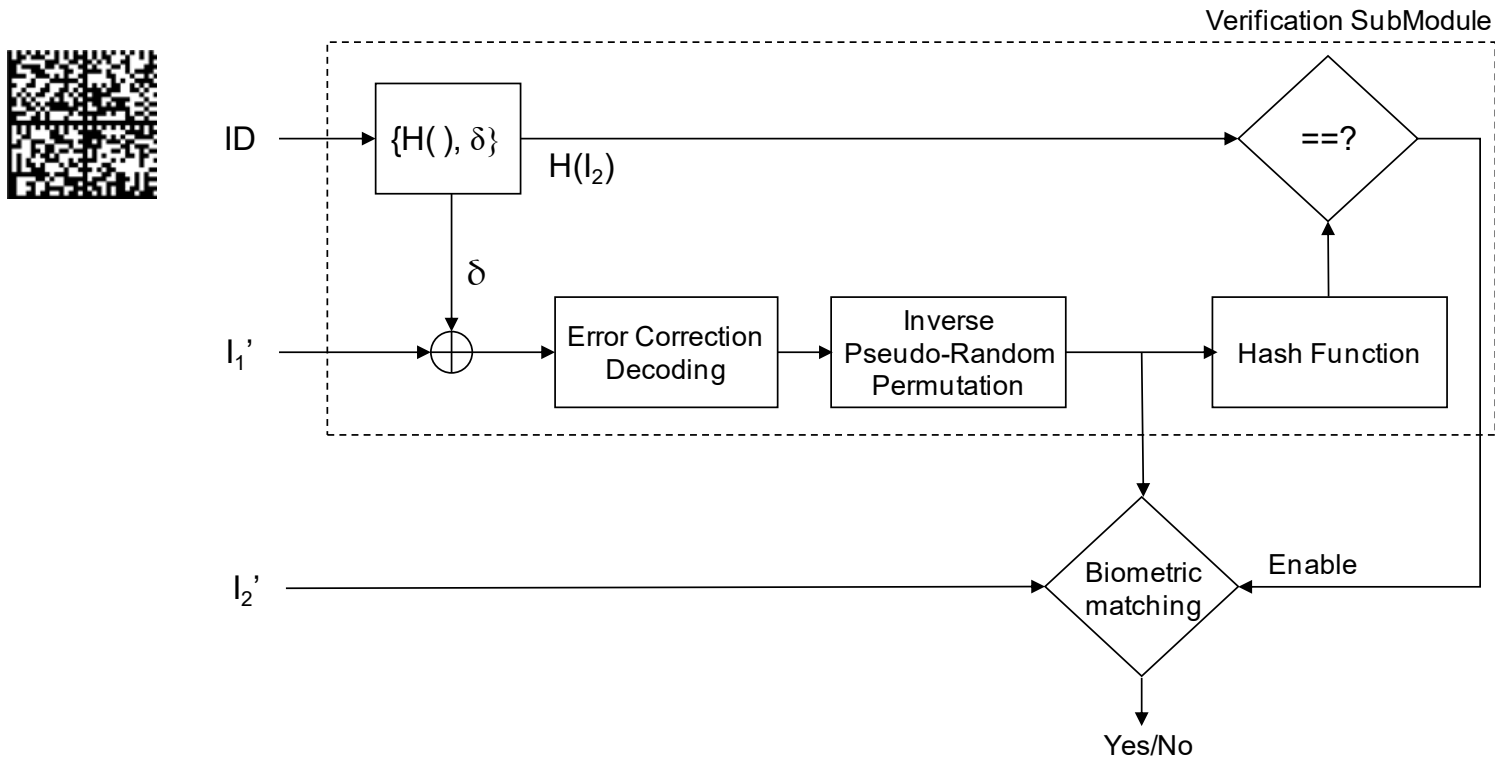


NOTES:

- 1) Given N_1 , the bit-length of I_1 , the code must be selected so that it corrects *at most* $r_1 N_1$ single bit errors on codewords which are N_1 bits long.

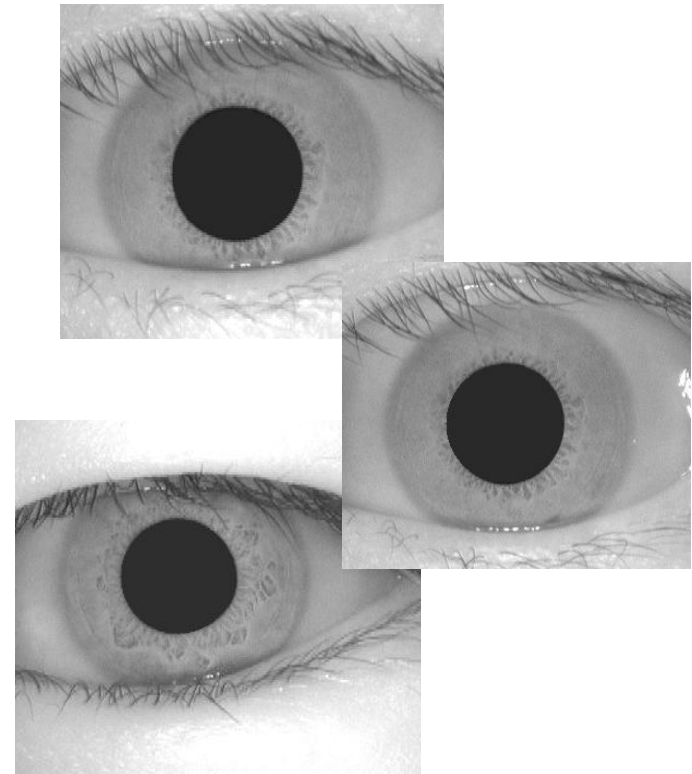
IrideSX+IrideDX Verification

Lo schema è un esempio, non è richiesto all'esame



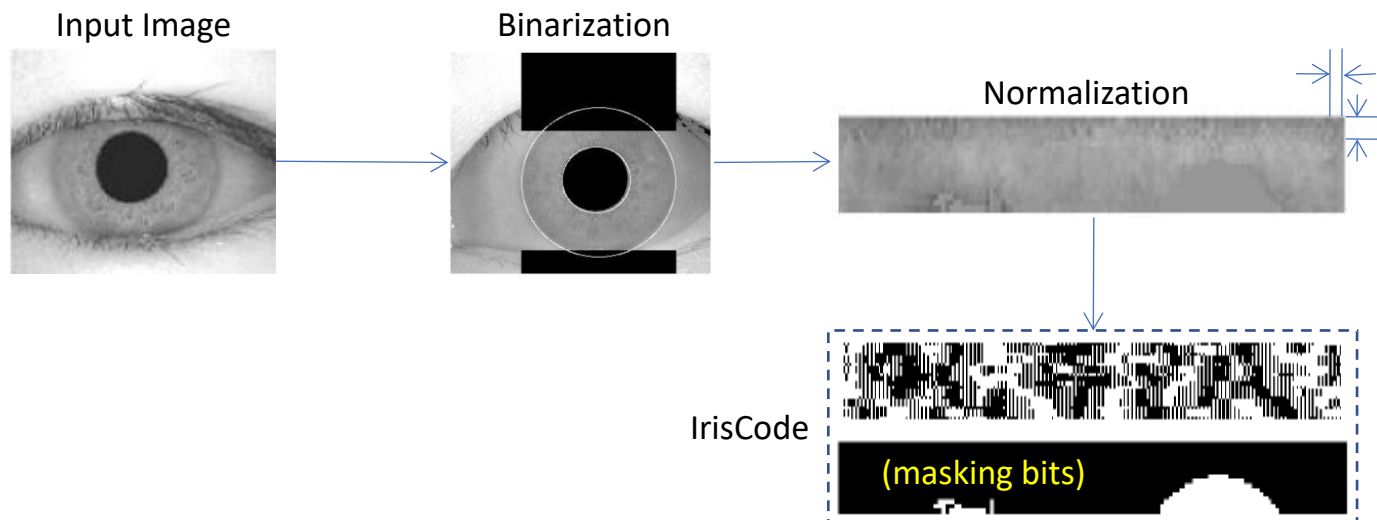
Esempio di risultati: CASIA dataset

- CASIA dataset (version 1.0) which contains seven images of the same eye obtained from 108 subjects
- Images were collected by the Chinese Academy of Science waiting at least one month between two capturing stages using near infrared light for illumination
- 3 images during the first session and 4 for the second one.



Implementation: the iris templates (2)

- Daugman method for creating the Iriscode Templates (public code library)



Implementation: the iris templates (2)

- Template I_1 : the right eye with 9600 bits (radial resolution = 20)
- Template I_2 : the left eye with 1920 bits (radial resolution = 20)
- Due to security issues, it is better to **not** include the masking bits of the iris code in the final templates since the distribution of zero valued bits in the masks is far from being uniform

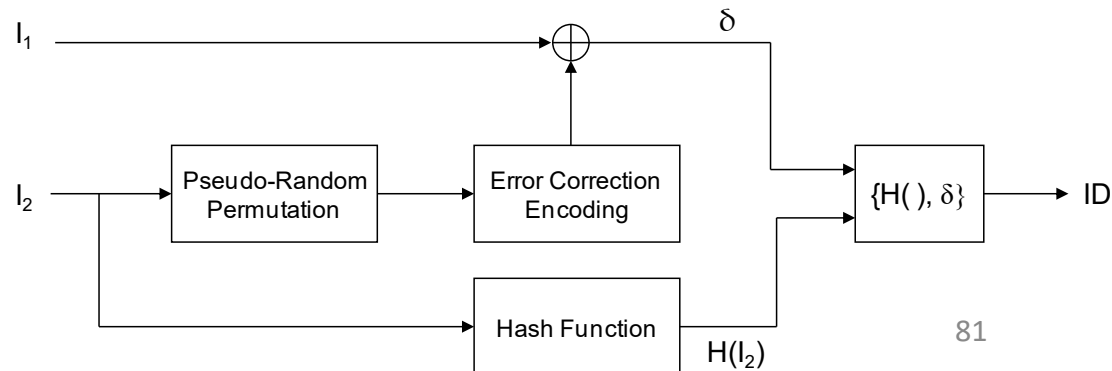
Implementation: the codes

- **Error correction code:**

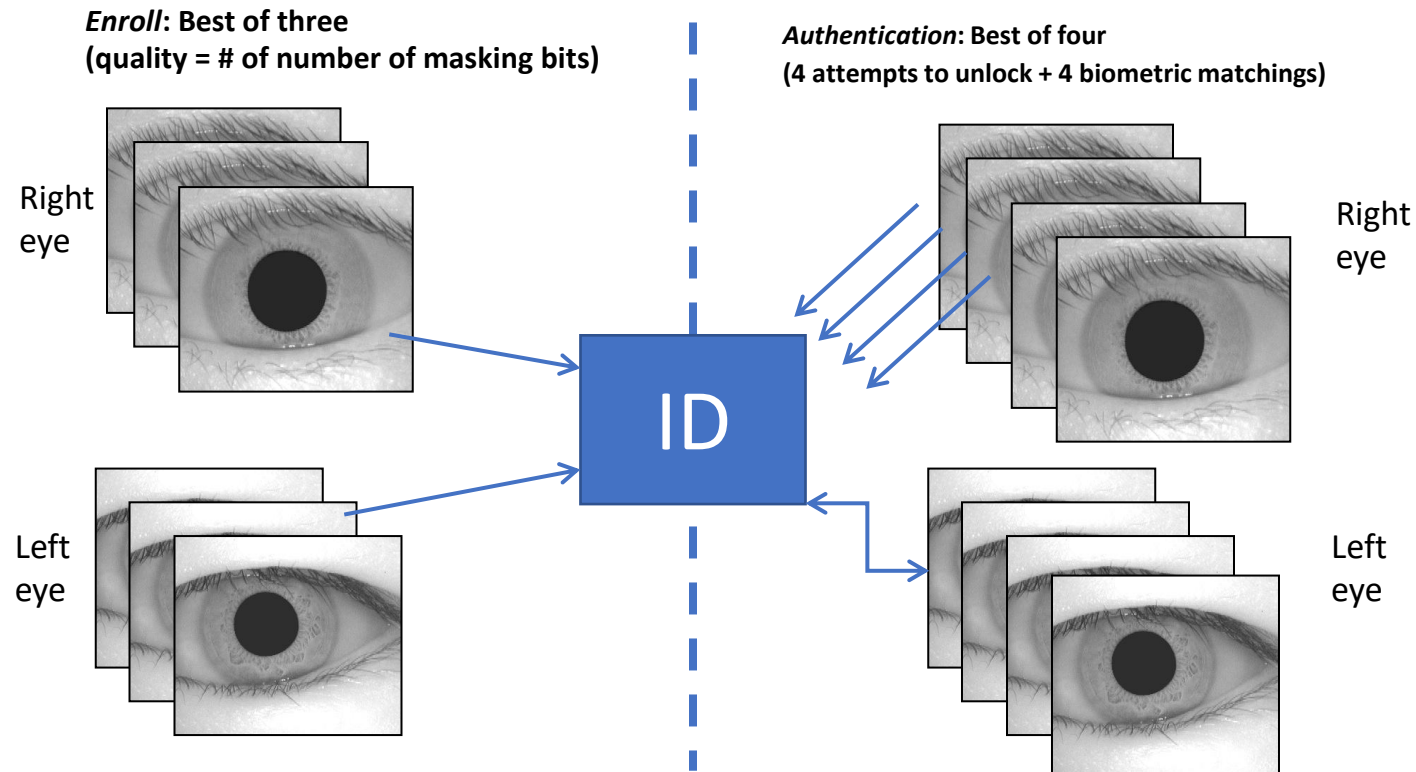
- Reed-Solomon $[9600, 1920, 7681]_{m=14}$
with $n_1 = 9600$ and $r_1 = 0.4$ (Optimal separation point between two different iris templates of genuines)
- In such set up, the scheme allows for up to $k = 1920$ bits for storing the second biometric template.

- **Pseudo random permutation:**

- AES in CTR mode

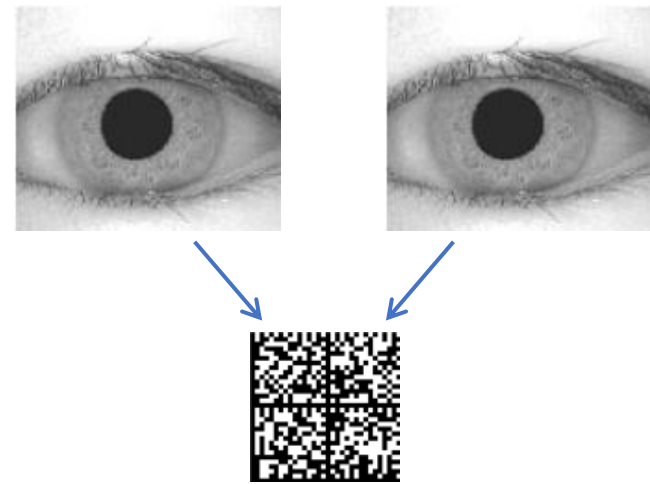


Implementation: enroll and authentication procedures



Performance

(concetti in esame)



Esempio di fusione biometrica con metodi crittografici
→ la accuratezza della fusione migliora

Componenti:

- Right eye system (9600 bits): EER= **0.5%**
- Lefty eye system (1800 bits): EER= 9.9%

Integration method:

- ERR: **0.96%**
- For a wide portion of the ROC curve, the proposed scheme achieves a better performance with respect to the best biometric system component (right eye).

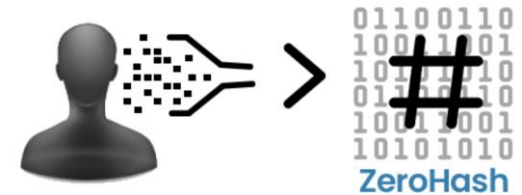
Conclusioni sulla applicazione della biometria come chiave

- Lo schema di esempio bilancia due aspetti: accuratezza e protezione
 - Peggiora leggermente l'EER rispetto al miglior singolo tratto biometrico (right eye, 9600 bits)
 - Ma bilancia con un miglioramento della privacy del template dell'utente che di fatto è inutilizzabile senza avere l'altro occhio disponibile "live" (e che non è mai stato memorizzato)
- I migliori metodi realizzano questo tipo di bilanciamento

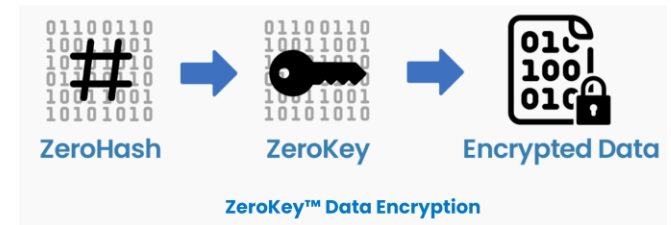
Primi esempi commerciali:

ZeroBiometrics (Face) <https://zerobiometrics.com/>

- ZeroFace™ generates a unique 256-bit ZeroHash for each person. No biometric or personally identifying information is needed or stored.
- Only ZeroFace can use your face to create cryptographic keys. ZeroKeys are created when you authenticate and are destroyed when you are offline to keep your data secure
- Dai dati disponibili sembra essere una trasformazione non invertibile



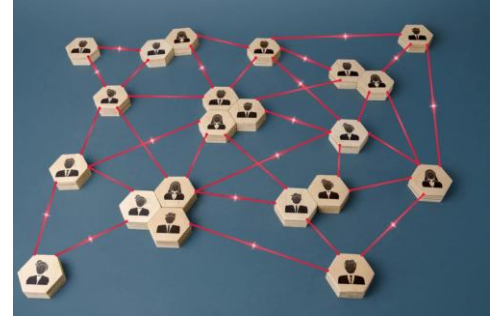
ZeroFace™ Doesn't Know What You Look Like



Altre applicazioni

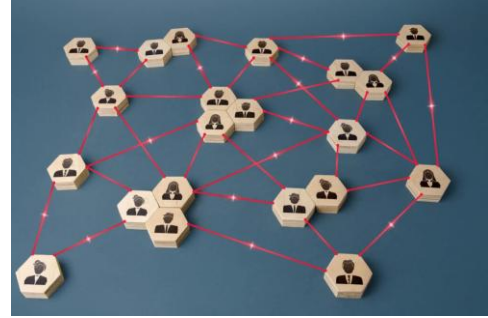


Decentralized Biometric Cryptosystem (DBC)



- Nei DBC l'informazione biometrica non è concentrata in un singolo database centrale, ma è memorizzata in modo distribuito o federato, utilizzando primitive crittografiche, per ridurre i rischi di compromissione, abuso e violazioni di privacy.
- I DBC **non sono** dei semplici sistemi biometrici distribuiti
- DBD = biometria + crittografia + distribuzione
 - Impegnano fuzzy commitment, fuzzy vault, secure sketch, MPC, ecc.

Decentralized Biometric Cryptosystem (DBC)



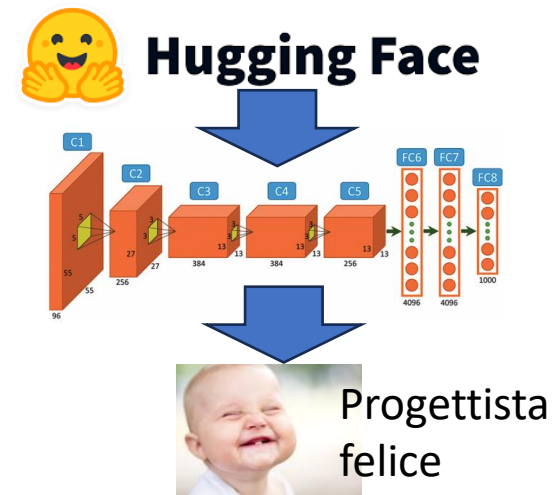
- Esempi
 - Applicazioni web3.0 costruite su Blockchain
 - Crypto-Biometrics-Coins
 - Vedremo un esempio completo nella lezione sul Proof of Personhood e Deep Fake
 - Decentralized biometric identity authentication in federated identity system. (Google Patents, [WO2018089098A1](#))

Feature di Privacy Protection nei SW biometrici da ricercare

Come progettista di un sistema biometrico occorre **verificare di avere** disponibili queste funzionalita'

- ANTI-PROFILING
 - Designed to prevent profiling by race/age/gender or national origin.
- ENCRYPTION
 - Image data is encrypted at rest and during transmission. Biometric templates cannot be converted into an image during a data breach.
- APPROVAL PROCESS (**GDPR** RELEVANT!)
 - Provisional enrollment functionality ensures appropriate management levels approve watchlist inclusion and creates an audit trail to prevent unauthorized usage.
- DATA PURGING
 - Watchlist images can be purged from the database according to a strict timeframe.

Bias e fairness nei modelli pre-addestrati



ATTENZIONE!

Non sono ancora molto diffusi modelli fondazionali “biometrici puri”, bensì *foundation models generalisti* che vengono *ri-adattati* (fine-tuning / prompting / adapter) a compiti biometrici.

Ecco i primi riallenati per biometria (praticamente sono fondazionali)

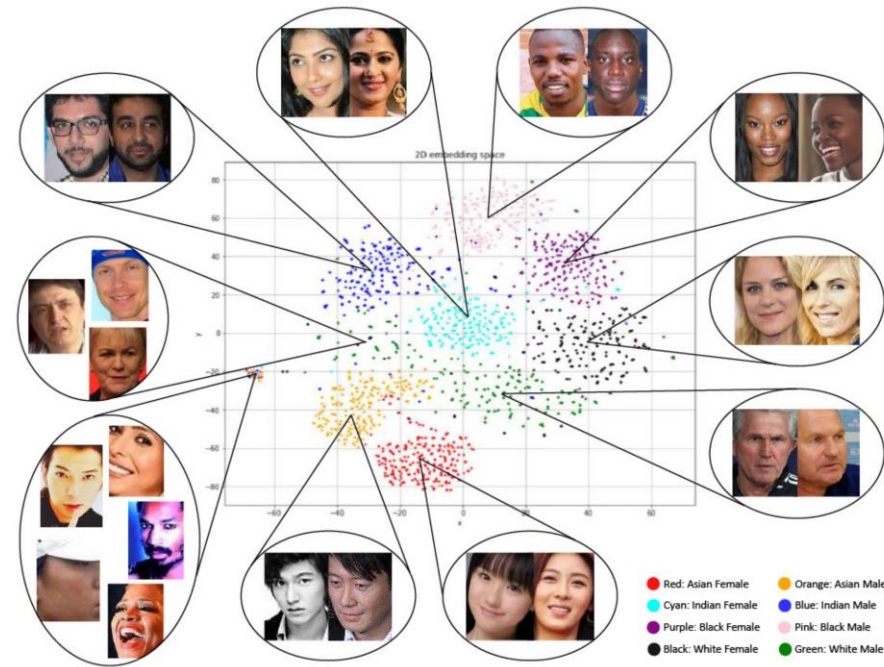
- Meta – DeepFace / DINOv2
- Google – FaceNet
- Microsoft – ArcFace (MS-Celeb-1M lineage)

Se il nostro sistema utilizza modelli fondazionali ri-allenati essi possono

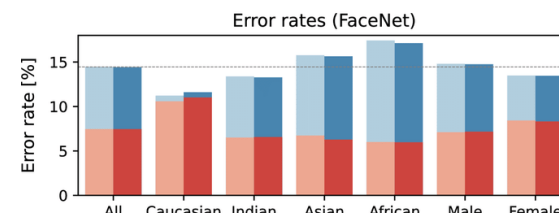
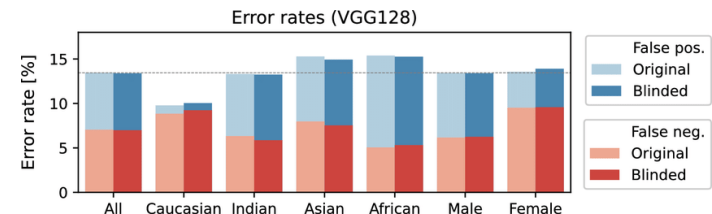
- **ereditare bias dai dati di pre-training**
- Si possono avere prestazioni diverse fra gruppi demografici che interagiscono con il sistema
- è un rischio concreto nel deployment biometrico

Esempi di bias osservati

- **Google – FaceNet**
FMR più alto per:
 - donne
 - pelle scura
 - giovani / anziani estremi
- **Microsoft – ArcFace**
Bias demografico sistemico
 - Etnia
 - Genere
 - Età
 - Bias di sorveglianza migliori performance su popolazioni “over-represented”



DeepFace / DINOv2 tende a clusterizzare per etnia, genere, età → le distanze sono diverse in base in che cluster ti trovi



VGG128 e FaceNet sbagliano molto di più Asiatici e Africani rispetto ai Caucasici

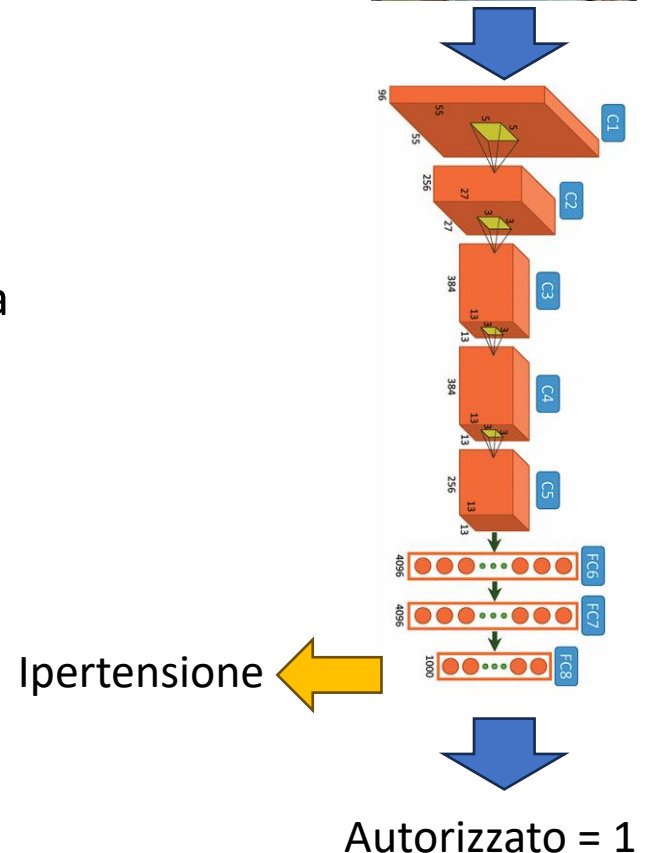
Cosa significa *Leakage informativo*

- Se trovi in un file che dovrebbe essere usato per farti entrare in una area aziendale del tuo dipartimento di informatica trovi scritto che tu *“sei in forte sovrappeso e a rischio di infarto”*, sei contento?
- **I vettori biometrici posso nascondere informazione in modo meno esplicito!**
- **Leakage informativo nei vettori biometrici**
 - Il template contiene più informazioni del necessario
 - Informazioni non richieste né autorizzate
 - Difficili da controllare a posteriori
 - Rischio per privacy e sicurezza

Molto importante!

Privacy $\leftrightarrow$ Vettori estratti

- “Un buon template biometrico deve essere **utile per il matching o la misurazione richiesta**, ma **inutile per qualsiasi altra cosa**.”
- Le reti ci ritornano dei vettori di caratteristiche che gestiamo nel sistema, ma non dovremmo essere in grado di estrarre informazioni di tipo non autorizzato dagli utenti
 - Gender, orientamenti, predisposizioni a malattie, profilazione non autorizzata, ecc.
- Vero in teoria, **difficile da evitare nella pratica**
 - Vedremo esempi e soluzioni nelle lezioni, ma occorre esserne consapevoli nella gestione di queste informazioni.
 - Sembrano vettori casuali e anonimi.... Non lo sono!)





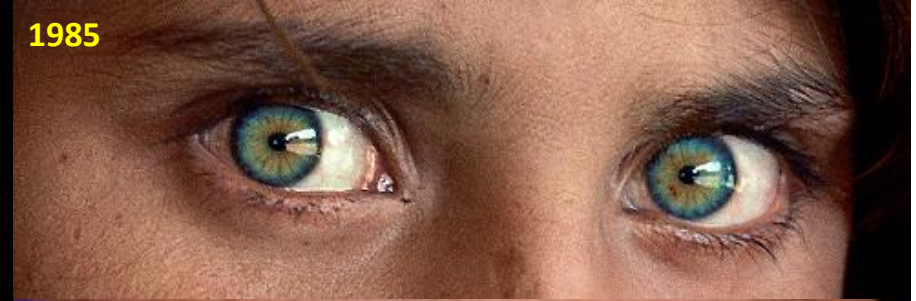
Discussione della privacy biometrica degli utenti nei social media

Quanto è preoccupante la diffusione dei nostri dati personali biometrici nei social media?

Caso di studio: riconoscimento di Sharbat Gula mediante iride



1985



2002



Steve McCurry è in Afghanistan per documentare la guerra civile. Nel campo profughi di Nasir Bagh (Pakistan) a confine con l'Afghanistan si ritrova casualmente in una scuola femminile dove scatta alcune foto.

Problemi di privacy? SI!!



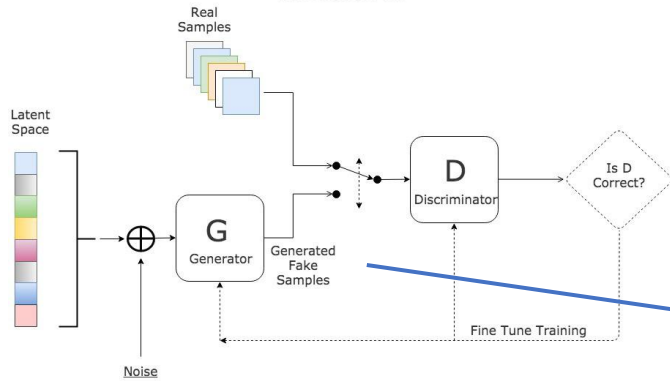
Sharbat
Gula
1985



Sharbat Gula
2002

- L'exploit di Daugman (riconoscimento con iride da foto ad alta risoluzione nel visibile a 18 anni di distanza) mostra la possibilità del pericolo di screening di massa dagli archivi di foto (governativi, social, ...)
 - Fattori chiave
 - Miglioramento delle tecniche di segmentazione e estrazione iriscodice nel visibile
 - Foto a ottiche dedicate, sempre maggiore risoluzione e perfetto fuoco sul volto (vedi selfie)
 - Capacità delle tecniche di iriscodice di avere dei FMR anche 10^{-7}
- **ENORME PROBLEMA DI PRIVACY NEL FUTURO**

Generative Adversarial Network



Possibile soluzioni:
IRIDE SINTETICA DEEP
(CNN generator)

IRIDE LINEARIZZATA



Cartesian->Polar + Segment.



Esempi



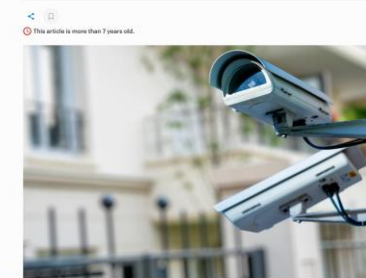
Applicazione di face morpher?

Puoi fare poco quando sono gli utenti stessi...

- **“Facebook 10 Year Challenge”**, una sfida virale del 2019 in cui milioni di utenti hanno pubblicato una foto di dieci anni prima e una attuale, spesso accompagnate da informazioni temporali esplicite.
- La viralità dell’iniziativa ha sollevato dubbi sul fatto che potesse costituire un **dataset ideale per l’addestramento di algoritmi di riconoscimento facciale**, in particolare per lo studio dell’invecchiamento del volto (*age progression*).
- Dal punto di vista tecnico, questo equivale a un **dataset etichettato ad alta qualità**, senza costi di acquisizione.
- **Facebook** (oggi Meta) ha negato ogni coinvolgimento diretto
- Solo una legislazione di tutela come il GDPR protegge gli utenti... diciamo... incauti...

Was The Facebook '10 Year Challenge' A Way To Mine Data For Facial Recognition AI?

By **Nicole Martin**, Former Contributor · © I write about digital marketing, data and privacy concerns.
Published Jan 17, 2019, 12:30pm EST, updated Jan 17, 2019, 06:56pm EST



From an security CCTV camera or surveillance system with private building in blurry background photo credit: Getty Images

Last week a new Facebook challenge went viral asking users to post a photo from 10 years ago and one from today captioning “how did aging effect you?” Now being called the “10-Year Challenge.” Over 5.2 million, including many celebrities, participating in this challenge. It follows closely after the “Bird Box Challenge” and the “Top Nine Photos of the Year Challenge” but this one has caused quite a stir and some concern from users.



Jessica Biel @JessicaBiel · Jan 13

What a difference ten years can make! Although I do still have a lot of ❤️ for my tan lines, hoops and blonde days... #10YearChallenge



426 533 15K

Jessica Biel's 10-year challenge on Twitter. Photograph: Jessica Biel/Twitter

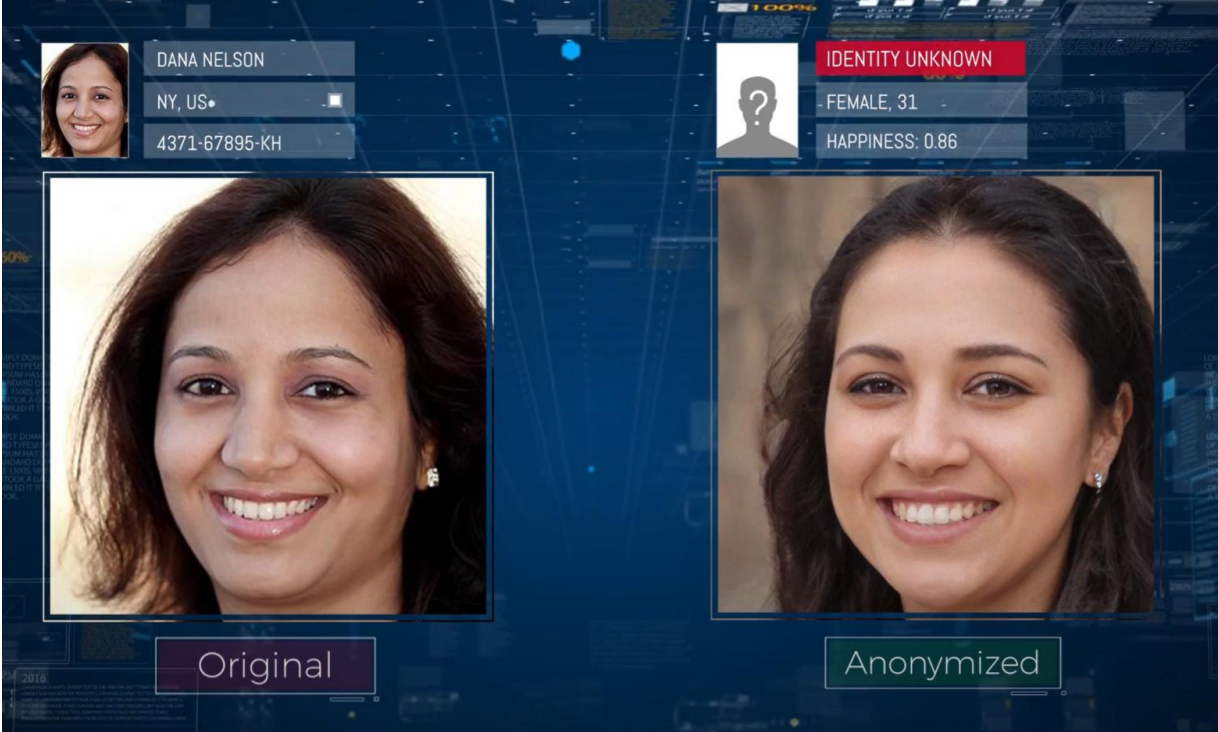
Rimozione della Personally Identifiable Information

- Nella gestione di dati per aziende e nuove applicazioni è importante avere dati/immagini/video, ma anche rimanere rispettosi di tutte le regolamentazioni (vedi GDPR)
- Esistono società che vendono software per rimuovere la **Personally Identifiable Information** (PII) da video e immagini.



Smart Anonymization (I-ID)

D-ID allows companies to use publicly-recorded video data in order to improve business performance using artificial intelligence analytics. Utilizing advanced computer vision, AI and [deep-learning models](#), D-ID removes Personally Identifiable Information (PII), while preserving key attributes such as age, gender, emotion, gaze etc.



Comparazione dei possibili scenari



Features	Security Application	Ambient Intelligence	Surveillance
Operational modalities	identification, verification	identification, verification, facilitation, preference-estimation, human-computer interaction	identification, behavior-detection, monitoring, tracking, watch-list
Overt/Covert	mostly overt	overt or covert	mostly covert
Most used traits	face, finger, iris	face, gait, voice, soft biometrics	face, gait
Touch-based/Touchless	touch-based or touchless	mostly touchless	touchless
Enrollment	required	required or not required	mostly not required



Inferenze Comportamentali e Stato Interno: Rischio Privacy

Negli ultimi anni, molti sistemi tecnologici hanno acquisito la capacità di **dedurre informazioni sul comportamento, sullo stato cognitivo o sullo stato emotivo** degli individui, anche quando i dati raccolti non nascono per scopi biometrici.

Questi sistemi (come vediamo nelle prossime lezioni) possono stimare:

- attenzione / distrazione
- livelli di affaticamento
- stress operativo
- calo cognitivo
- emozioni
- micro-espressioni o posture anomale
- pattern comportamentali ricorrenti

Il punto critico per la privacy

Queste inferenze, se riconducibili a un individuo identificato, diventano **informazioni sensibili** e possono essere classificate come una **forma di biometria comportamentale** (esplicita o implicita).



La tua produttività e' scesa oggi!



Il tuo cliente non era contento!
Tu non sorridevi al cliente!

Caso Uiguri

Etnia turcofona di religione islamica
che vive nel nord-ovest della Cina

- Da Tg24 Sky, (28 nov 2019)
Il 18 novembre 2019 il New York Times ha pubblicato più di 400 pagine di documenti riservati che descrivono il giro di vite della Cina contro le minoranze etniche musulmane nella regione di Xinjiang, in particolare gli uiguri, rinchiusi in campi di prigionia o nelle carceri
<https://tg24.sky.it/mondo/approfondimenti/uiguri-cina>
- AsiaNews
The Chinese are accused of imprisoning 1.8 million Uyghurs, Kazakhs and Kyrgyz in camps. The number of signatories has more than doubled since the first official complaint in 2020. 43 nations have joined the United Nation in condemning the atrocities committed by the Chinese government against the Turkish-speaking Muslim minorities living in Xinjiang and other provinces in the country.
- The Chinese deny all accusations, claiming that the Xinjiang structures are vocational training centres and projects to reduce poverty, fight terrorism and separatism
<https://www.asianews.it/news-en/UN:-43-nations-condemn-Beijing%27s-atrocities-in-Xinjiang-54346.html>



Workers walk along the perimeter fence of what is officially known as a **vocational training centre** in Dabancheng, Xinjiang. China is under growing international pressure over its policies in the far western region Photo: Reuters (*)

Caso Uiguri

Da The Guardian (7/1/2022)

- SenseTime, China's largest facial recognition startup, claims to have the ability to 'classify Uyghurs'
- SenseTime has come under increasing scrutiny by the US government for its alleged role in the surveillance of Uyghurs
- In July 2019 when SenseTime filed a patent for a facial recognition feature that could, among other things, distinguish between people who were and were not ethnically Uyghur

<https://www.theguardian.com/world/2022/jan/06/china-sensetime-facial-recognition-uyghur-surveillance-us-sanctions>



SenseTime surveillance software

«Le violazioni nei loro confronti si sono intensificate dal 2001, presentate come una campagna di lotta al terrorismo»

<https://tg24.sky.it/mondo/approfondimenti/uyguri-cina>

!! PERSINO DIETRO UN «SEMPLICE» TRATTO DI SOFTBIOMETRICS POSSONO CELARSI ENORMI PROBLEMI DI PRIVACY !!

Attenzione alla normativa (moratoria ora terminata)

- La moratoria che vietava in Italia l'installazione e l'uso di sistemi di riconoscimento facciale tramite dati biometrici, a meno che il trattamento non sia effettuato per indagini della magistratura o prevenzione e repressione dei reati e' terminata il 31/12/2025.
- La moratoria nasceva dall'esigenza di disciplinare requisiti di ammissibilità, condizioni e garanzie relative al riconoscimento facciale, nel rispetto del principio di proporzionalità.
 - Solo che nel frattempo non sono state forniti casi d'uso e indicazioni generali.

Nuovo Decreto Sicurezza Febbraio 2026

il Governo ha approvato nuove norme che consentono l'uso del riconoscimento facciale "**a posteriori**" (analisi delle registrazioni dopo che è avvenuto un fatto) in contesti specifici, come gli **stadi e gli impianti sportivi**, per identificare autori di reati o violenze.

- **il volto di chi andrà allo stadio verrà rilevato** da sistemi di identificazione facciale e finirà in un database, al quale si potrà accedere nel caso in cui vengano commessi dei reati.
- **No canceling**: non si potrà entrare con cappucci o sciarpe o passamontagna che nascondano il volto)
- **Tutti gli stadi** di serie A dovrebbero quindi essere dotati una telecamera per ogni tornello



La posizione del Garante Privacy (per l'Italia)

Settore Privato

- Per i soggetti privati (negozi, hotel, aziende), l'uso del riconoscimento facciale rimane **di fatto vietato nella quasi totalità dei casi**, poiché è estremamente difficile ottenere un consenso realmente libero e informato in contesti aperti al pubblico o caratterizzati da uno squilibrio di potere. Inoltre, il trattamento risulta in genere **non necessario né proporzionato** rispetto a soluzioni meno invasive.

Trasporto pubblico

- Nel **febbraio 2026** il Garante è intervenuto per **bloccare sistemi di “facial scanning”** utilizzati in ambito aeroportuale come sostituzione del biglietto, in assenza di adeguate garanzie tecniche (in particolare sulla cifratura) e di un **controllo effettivo e continuativo da parte dell'utente** sul proprio dato biometrico.
 - Vedi lezione su ABC e aree ad elevata sicurezza

Particolare attenzione ai segnali fisiologici e “Heart biometrics”!

Esistono molti device consumer (largamente diffusi!) in grado di leggere segnali fisiologici, specialmente quelli cardiaci



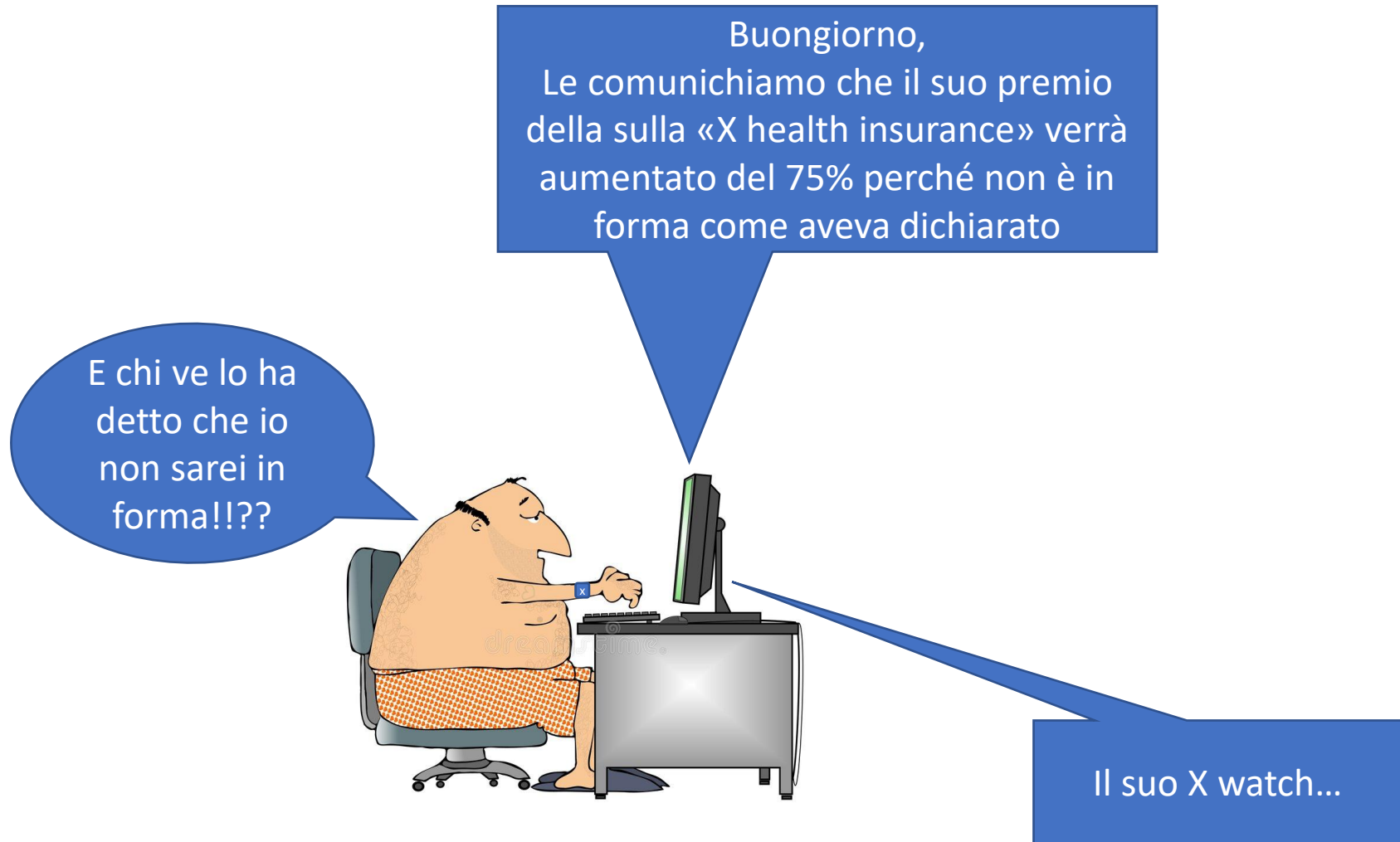
Il tuo stato di salute è esposto e può essere trasmesso/diagnosticato



<https://ouraring.com/>

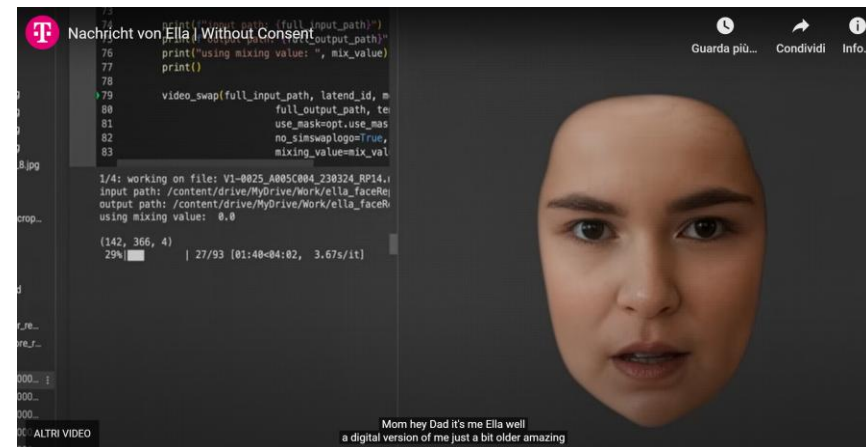


Humor ?



Raccomandazioni di buon senso e «Sharenting»

- Di particolare efficacia (quasi disturbante per alcune persone) lo spot sulla privacy dei dati dei minori condivisi da parte dei parenti (Sharenting)



- https://youtu.be/F4WZ_k0vUDM
- [Telekom.com/share-with-care](https://www.telekom.com/share-with-care)



Sommario

1. Difesa della Privacy and linee guida
2. Biometria cancellabile
 - Permutazione per iris code
 - Morphing del volto (esempi)
3. Sample o template (ricostruzione del sample)
4. Crittazione Biometrica
5. De-identificazione biometrica
6. Discussione della privacy biometria nei social media
7. Ulteriori rischi associati alla heart-biometrics

Considerazioni finali

- La **protezione a livello di template** biometrico
 - è un buon metodo per migliorare la privacy, usabile e fattibile
 - necessità di metodi più complessi dei normali algoritmi biometrici tradizionali
 - può abbassare la accuratezza del rispettivo sistema biometrico tradizionale
 - non vengono (purtroppo) quasi mai impiegati nelle applicazioni sia commerciali sia governative
 - di solito si preferiscono delle tecniche crittografiche tradizionali per proteggere il canale trasmissivo, la memorizzazione dei template
- L'**elaborazione biometrica nel dominio crittato**
 - è promettente e applicabile
 - Attualmente solo per alcuni metodi di matching semplici possono essere usati (arrivando a CNNs, no funzioni matematiche non lin.)